

SRINIVAS UNIVERSITY

Mukka – 574146, Mangalore, India, Phone: 0824-2477456

**(State Private University Established by Karnataka Govt. Act No. 42 of 2013
empowered to award degrees under Section 22 Of UGC Act of UGC, New Delhi, &
Member of Association of Indian Universities, New Delhi)**

Web: www.srinivasuniversity.edu.in, Email: info@srinivasuniversity.edu.in



STUDY METERIAL

For

Introduction to Cloud Security

**IIIst Semester Bachelor of Computer Application
(BCA)(2022-23)**

INSTITUTE OF COMPUTER SCIENCE & INFORMATION SCIENCES

SYLLABUS

Paper : 21CAC-9/CC Theory/Week: 3 Hours Credits: 3	Introduction to Cloud Security	Hours: 30 IA : 50 Exam: 50
Course Objective: - To train the student in understanding the concepts of Cloud Security - To Train the students in understanding the concept of virtualization - To train the students about the cloud computing architecture - To understand the cloud security management		
Course outcome: After the completion of the course students will be able CO1: To Apply various techniques in virtualization domain CO2: To develop various models for cloud security CO3: To work with the cloud computing architecture CO4: To work for cloud security management and various audit and compliance.		
Module – I: Introduction to Virtualization		6 Hours
Impact and business benefits of Virtualization. Risks of Virtualization including attacks on Virtualization infrastructure, Hyper jacking and Virtual Machine jumping. Hyper jacking attacks like Blue Pill, Sub Virt, Vitriol, attacks on Virtualization features and compliance and Management challenges. Strategies and counter measures for addressing Virtualization risks.		
Module – II: Introduction to Cloud Security		6 Hours
History of Cloud Computing, characteristics of cloud computing, architecture influence, technology influence, Operational influence, Various Cloud Delivery, Trusted Cloud Initiative (TCI) and Cloud Trust Protocol (CTP). Transparency as a Service (TaaS) and Security as a Service (SecaaS), Top Threats to Cloud Security, Cloud Security Services: Authentication, Authorization, Auditing & Accountability (AAAA), NIST 33 Security Principles, Secure Cloud Software Testing: Testing for Security Quality Assurance & Cloud Penetration Testing.		
Module – III: Cloud Computing Architecture		6 Hours
Cloud delivery models, Cloud deployment models, Architectural consideration, Identity management and access control, Autonomic security, Governance and Enterprise Risk in the Cloud. Legal and Electronic Discovery in the Cloud. Compliance and Audit issues in the Cloud. Portability and Interoperability issues in the Cloud. Traditional Security, Business Continuity Management and Disaster Recovery in the Cloud.		
Module – IV: Cloud security management		6 Hours
Security management standards, Security management in the Cloud, Availability management: SaaS availability management, PaaS availability management, IaaS availability management. Access control, Security vulnerability, Patch and configuration management. Encryption and Key Management in the Cloud, Identity and Access Management in the Cloud, relevant IAM standers and protocols for cloud services.		
Module – V: Audit and Compliance		6 Hours

Key privacy concern in cloud, Changes to privacy risk management and compliance in relation to cloud computing, Legal and regulatory implication, Internal policy compliance, Governance, Risk and Compliance (GRC), Control objective of cloud computing, control consideration for cloud service provider users, Regulatory or external compliance, cloud security Alliance, Auditing cloud for compliance.

TextBooks:

1. Cloud Security: A Comprehensive Guide to Security by Ronald L. Krutz, Russell Dean Vines (Paperback).
2. Cloud Security and Privacy: An Enterprise Perspective on Risks and Compliance By Tim Mather, Subra Kumaraswamy, Shahed Latif (Paperback)

ReferenceBooks:

1. Practical Cloud Security: A Cross-Industry View by Melvin B. Greer Jr., Kevin L. Jackson CRC Press; 1 edition (2 August 2016) (Paperback)
2. Virtualization Security: Protecting Virtualized Environments Book by Dave Shackleford (Paperback).

Continuous Internal Assessment (CIA) Method:

Sl. No	Type of Assessment	Mode of Assessment	Marks
1	Presentation on any topic on the subject	Regular mode of Assessment	10
2	Open Book Examination	Regular mode of Assessment	10
3	Assignments on Topic	Regular mode of Assessment	10
4	MCQ at the end of each module	2 marks for each Module	10
5	Attendance and Extracurricular activity	As per the regulations	10
Total			50

Scheme of Evaluation:

The paper carries 100 marks out of which 50 marks will be allotted to external examination and 50 marks will be allotted to the internal assessment.

External examination marks will be as follows

1 marks questions 10 out of 12

1 X 10 = 10

marks One full question out of 2 full questions in each Module carries 8 X 5 = 40 marks

Total 50 marks.

In order to clear this paper minimum 50% marks must be scored both in internal and well as external examination.

Video Links

1. <https://www.youtube.com/watch?v=zLJbP6vBk2M>
2. <https://www.youtube.com/watch?v=FZR0rG3HKIk>
3. <https://www.youtube.com/watch?v=ImpRCrMYSTc>
4. <https://www.youtube.com/watch?v=vQaInnaU8c0>
5. <https://www.youtube.com/watch?v=X43KVeWVksY>
6. <https://www.youtube.com/watch?v=z11VgAv5XXI>
7. <https://www.youtube.com/watch?v=0lw4KU5wHsk>
8. <https://www.youtube.com/watch?v=MmzEL36cLJ8>
9. <https://www.youtube.com/watch?v=w4rx8DZX8nI>
10. <https://www.youtube.com/watch?v=-dUuot0bano>

Module – I

Introduction to Virtualization

Impact and business benefits of Virtualization

- In the late 90's and early 2000's Virtualization really started to take a foothold in the Corporate Enterprise market, and today the applications of this technology have made it a must-have for all businesses
- There are many types of Virtualization solutions businesses have adopted, such as Server Virtualization, Desktop Virtualization, Storage Virtualization and Network Virtualization just to name a few
- Server Virtualization:
 - o Using server virtualization, multiple operating systems can run on a single physical server as virtual machines, each with access to the underlying server's computing resources
 - o Most servers operate less than 15 percent of capacity; not only is this highly inefficient, it also introduces server sprawl and complexity
- Desktop Virtualization:
 - o Rather than interacting with a host computer directly via a keyboard, mouse, and monitor, the user interacts with the host computer using another desktop computer or a mobile device by means of a network connection, such as a LAN, Wireless LAN or even the Internet.
 - o In addition, the host computer in this scenario becomes a server computer capable of hosting multiple virtual machines at the same time for multiple users.
 - o For users, this means they can access their desktop from any location, without being tied to a single client device.
 - o Since the resources are centralized, users moving between work locations can still access the same client environment with their applications and data.
- Network Virtualization
 - o Network virtualization is the complete reproduction of a physical network in software.
 - o Network virtualization presents logical networking devices and services—logical ports, switches, routers, firewalls, load balancers, VPNs and more—to connected workloads
 - o Applications run on the virtual network exactly the same as if on a physical network.

Business Benefits:

1. Redundancy and instant failover abilities

Without redundancy, many businesses would experience numerous problems with lost data. Virtualization provides instant failover abilities which make things more efficient. Two servers are usually connected so that if one experiences problems, the other can continue working as if nothing happened. Such activity prevents unnecessary interruptions that would otherwise lead to losses.

Redundancy and failover abilities come in handy during data recovery as it ensures optimal performance and rapid data restoration in cases when data is deleted or damaged. It can even recover when physical disks fail and are unrecoverable.

2. Smooth migration of resources

Virtualization makes it easy to switch from physical to virtual infrastructure as the need arises. Different technologies allow for virtual disk storage, but you can quickly turn to physical storage. You also have the option to migrate from a fully allocated virtual disk to a thin-provisioned virtual disk. This way, administrators can prevent the wastage of resources by providing only what's needed at a particular time without negatively impacting operations.

3. Virtual firewalls and security

Business ventures can benefit from virtual firewalls to protect access and data at lower costs than traditional methods. Virtual security involves using advanced controls such as a virtual switch to protect against malicious attacks from unverified sources.

Applications are isolated to make them untouchable from malware, viruses, and even applications that may stop the execution, to name but a few threats.

Firewalling features are provided at the base of network virtualization platforms to bring about segmentation. It allows automated provisioning and context sharing across virtual

platforms, which leads to increased visibility and security across applications on virtual or physical workloads. Improved security through virtualization helps you gain mileage over challenges that would otherwise ruin your reputation among clients. This would be disastrous, as your businesses rely on clients to make profits.

4. Improved IT support

Companies must provide excellent customer support to keep or maintain their customers. This can be quite a challenge for ventures without enough manpower to provide customer support when it is needed. Moving to the virtual space is a great solution that instantly improves IT support to ensure a seamless data flow for various operations.

5. Reduced costs and a greener environment

The traditional one enterprise app for one server model set the stage for increased costs and underutilized servers in the standard hardware model. This is the opposite with virtualization, as machines are consolidated across fewer physical servers reducing compatibility issues and cutting costs. There is no wastage with this approach, ensuring virtual machines are allocated just the necessary resources. In so doing, virtualization reduces the data centre's carbon footprint, which goes a long way in preserving the environment. Virtualization significantly saves space for companies investing in more profitable operations. You need less networking gear, fewer servers, fewer racks, and ultimately less room for the data centre. Further savings can come from shared technology as opposed to personal data centers.

Virtualization in cloud computing environments has become an increasingly popular option for businesses. There are many benefits of virtualization in a cloud environment. This article will help you determine whether virtualization is right for your organization.

First, we will briefly examine how virtualization works.

Virtualization uses software to create a virtual system that mimics hardware functionality. This process allows IT organizations to run multiple virtual systems—as well as multiple operating systems and applications—on a single server.

Virtual machines (VMs) are software containers with an operating system and application inside. When multiple VMs run on one computer, more than one operating system and application can run on the same server or **host**. A hypervisor decouples VMs from the host and dynamically assigns computing resources to each.

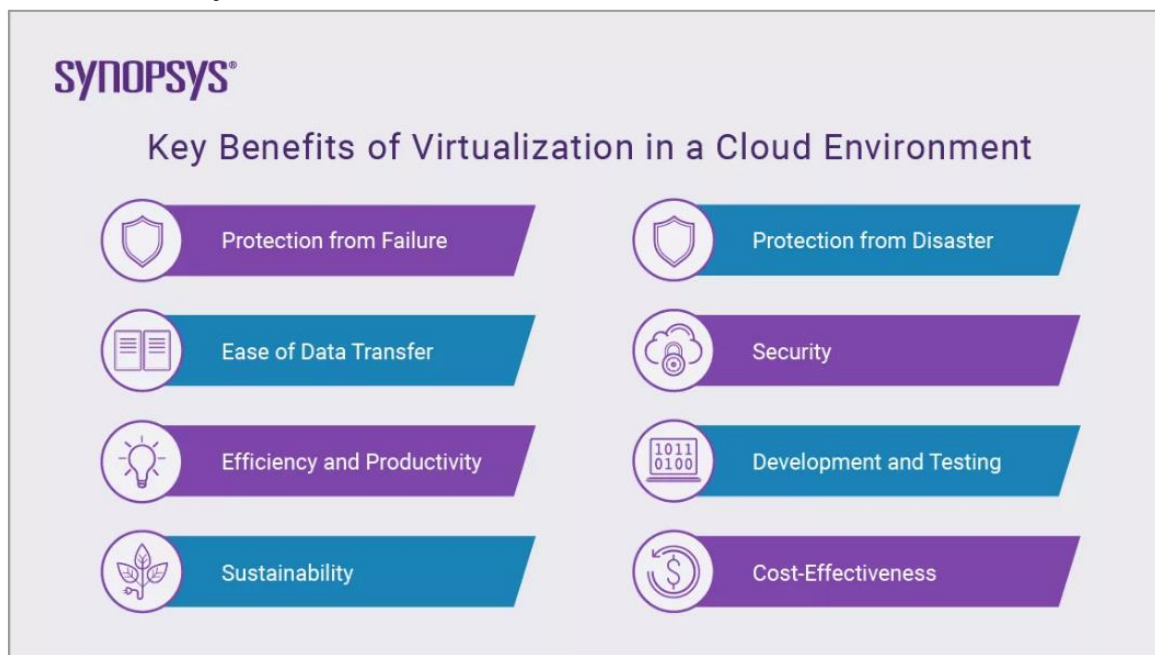
Now, we will explore the benefits of virtualization in a cloud environment

Key Benefits of Virtualization in a Cloud Environment

Protection from Failure and Disaster

Virtualization in cloud computing can prevent your IT system from failing. Even if one part of your system crashes, it doesn't mean the entire system will. A virtual machine helps protect your IT environment from bugs, viruses, and crashes when you are testing software or trying out a new program.

After a disaster, it can take days to replace or fix a physical server. In a virtualized environment, it is easy to provision and deploy VMs, so you can replicate or clone those affected. Instead of having to provision and set up a new physical server, the recovery process takes mere minutes, enhancing the environment's resiliency and business continuity.



Ease of Data Transfer

Another benefit of virtualization in a cloud environment is the ease of data transfer. You can transfer data easily between virtualized devices and servers without searching through physical hard drives or data centers. With virtualized desktops and storage, you can transfer entire machines without moving any physical infrastructure. As a result, you'll save time, energy, and money.

Security

Virtualization offers significant security benefits in the cloud. Because VMs and virtual infrastructure stay separate from other parts of your systems, it's much harder for viruses and malware to spread.

With virtual firewalls, you can restrict access to your data for much less money than with traditional methods. Virtualization protects you from many potential cybersecurity issues because a virtual switch shields your data and apps from malicious malware, viruses, and other threats.

With cloud server virtualization storage, you won't have to worry about data loss or corruption. Cloud providers offer encryption using high-end protocols to protect your data. Virtualization gives you premium-level data security without the cost of physical firewalls.

Efficiency and Productivity

You'll spend less time maintaining the hardware and IT infrastructure when you have fewer servers. Instead of applying updates server-by-server, you can install, update, and maintain the environment for all VMs in the virtual environment on one server. Your team will be more efficient and productive if you spend less time maintaining equipment.

IT teams also use virtualization to solve complex, nuanced technical issues in the cloud. Since data is always available in a virtual server, IT doesn't have to worry about data recovery from crashed or corrupted devices.

Development and Testing

Virtualized environments are segmented into virtual machines that developers can quickly spin up without affecting the production environment. Developers can also quickly clone a virtual machine and run tests on it.

For example, a developer can clone the virtual machine, apply a new software patch, test the environment, and then pull it into the production application. This process speeds up application development.

Sustainability

Virtualization improves sustainability by cutting the number of physical servers and the amount of power you consume. This decrease significantly reduces the carbon footprint of the data center.

Cost-Effectiveness

Virtualization is a great way to cut expenses. If you store data on virtual servers or clouds, you won't have to buy physical hardware or systems. You can therefore reduce your waste, electricity, and maintenance costs. Additionally, virtualization saves you a lot of server space, which you can then use to improve operations

Top virtualization security issues

External attacks

If attackers gain access to your host-level or VMware vCenter server, this opens doors for them to access other important VMs, or even create a user account with admin rights that could be used over a long period of time to collect or destroy sensitive company data.

Keeping snapshots on VMs

Snapshots are meant to be retained for only a short time. Attackers or malicious insiders could collect valuable data from snapshots.

Sharing files between VM and host, or copy-pasting between host and remote console

By default, file sharing between VM and host is disabled, as is copy-paste between VM and remote management console. While it is possible to override these defaults using advanced ESXi host system settings, it is not recommended. An attacker who gains access to the management console would be able to copy sensitive data outside of the virtual environment or introduce malware into the VM.

VM sprawl

Another important security risk is the proliferation of VMs, which is often caused by developers or IT admins creating VMs for testing purposes but failing to delete them once the testing period is over. In fact, VMs can be created so easily that IT teams have a tough challenge to track how many there are, and when and where

they are deployed. As a result, these VMs are often left unpatched and unprotected. In addition to being vulnerabilities, they also consume valuable hardware and other resources. Proper lifecycle management conducted on regular basis using VM inventory reporting software is the best way to control VM sprawl.

Viruses, ransom ware and other malware

VMs are vulnerable to many different kinds of attacks. One of the most common is ransom ware, such as Crypto locker. It's essential to maintain regular backups of your data off site, where they cannot be encrypted; without backups, you might have to pay the hackers to provide the decryption key. However, even with proper backup management, restoring many VMs is difficult and time consuming. Therefore, you should also train all users on a regular basis to minimize the risk of introducing ransomware.

Best practices for keeping your virtual environment safe

It's essential to follow general security best practices. In addition, here are two of the most important strategies properly securing your virtual environments:

Use named users and least privilege

For daily purposes, be sure to use only non-root user accounts for connecting to ESXi hosts. Create a named administrator user in vCenter Server and assign specific users that administrator role so you can determine exactly which user logged into what host, at what time, etc., and hold them accountable for the changes they make to your environment.

Secure all the parts of the infrastructure

All parts of the infrastructure must be properly secured, from the physical infrastructure (hosts, switches, routers, physical storage) through the virtual infrastructure and guest operating systems, as well as any cloud environments you use. In particular:

- Hosts should have latest firmware installed and virtualized infrastructure (VMware vSphere or Microsoft Hyper-V) should have the latest security patches installed. It is also important to keep the VMware tools on your virtual machines up to date.
- All active network elements (switches, routers, load balancers for balancing workloads, etc.) should have the latest firmware deployed.
- Every operating system should be fully patched via automatic updates. Patch installation should be scheduled for outside of business hours with automatic reboots.
- Install proper antivirus and antimalware solutions designed for virtualized environments.

Have a strong backup and disaster recovery (DR) plan

A proper backup and DR plan is essential for ensuring business continuity, whether you suffer a malware attack or a hurricane brings down your production datacenter. Having a DR site at a remote datacenter or in the cloud helps mitigate the risk of prolonged downtime. Here are two important tips to keep in mind as you create your DR plan:

- **Back up VMs and physical servers** — While it is not possible to back up ESXi itself, it is possible to back up its configuration via the VMware command-line and the scripting application Power CLI. Today, you can use the same tools to back up both physical systems running Windows or Linux and VMs running any OS.
- **Use the 3-2-1 backup rule** — Create and keep at least 3 copies of your data and store 2 backup copies on different storage media, with 1 of them located off site.
- **Consider replication** — For more DR protection, you can replicate your production VMs to another datacenter, which you can failover to quickly if needed.

Virtualization security tools to protect your environment

Antivirus and anti-malware software

I recommend TrendMicro, which has a nice integration with VMware and offers hybrid-cloud security for organizations that have both on-premises and cloud (Amazon AWS or Microsoft Azure) environments. TrendMicro's Deep Security software runs at the hypervisor level and installs a small agent in the guest OS. It offers an optional integrated firewall, intrusion prevention system (IPS), and integrity monitoring that runs at the agent level. It is an end-to-end, all-in-one solution with a single dashboard and remote deployment capabilities, so you can deploy the lightweight agents to all of your VMs from a single location. To prevent AV storms (where AV software scans the VMs at the same time or at boot), the Windows agent includes an anti-malware scan cache with hashes of previously scanned files that are frequently accessed, so they don't have to be rescanned every time.

McAfee, Sophos and Symantec also offer AV software solutions that are compatible with VM environments.

Backup and replication software

Veeam Backup and Replication can protect physical and VM environments (including hybrid and cloud), and you can manage everything from a single console to ensure proper protection. You can implement the 3-2-1 backup rule, and create and maintain backup files off site in line with best practices. It also offers replication to ensure fast restoration of services if your primary datacenter goes down.

Nakivo, Vembu Technologies and Altaro also offer data backup solutions that are compatible with VMware.

Change auditing software

Monitoring changes across your virtual environment is essential for security. One such virtualization security tool is Netwrix Auditor for VMware. It tracks changes to the configuration of the whole datacenter and its various objects (resource pools, clusters, folders, VMs), and also monitors logons to your virtual environment.

Modern organizations need to defend their virtual environments against a wide range of threats. Key strategies include keeping all software up to date, using AV software, following configuration best practices

and conducting regular user training. But even with the best defenses, some threats will get through, so it's essential to invest in security tools that can track changes and logons to help you maintain security at all levels, all the time.

What Does Virtual Machine Hyper Jumping (VM Jumping) Mean ?

Virtual machine hyper jumping (VM jumping) is an **attack** method that exploits the hypervisor's weakness that allows a virtual machine (VM) to be accessed from another. The vulnerabilities allow remote attacks and malware to compromise the VM's separation and protections, making it possible for an attacker to gain access to the host computer, the hypervisor and other VMs, in addition to being able to jump from one VM to another.

Virtual machine hyper jumping is also known as **virtual machine guest hopping** (VM guest hopping). Virtual machine hyper jumping exploits are designed to compromise a VM, which is then used to access or launch attacks against other VMs or hosts. This is usually done by targeting and accessing a **less secure VM** on a host, which is then used as the launch point for further attacks on the system.

In some severe attacks, two or more VMs may be compromised and used to launch attacks against the more secured guests or hypervisor. A compromised guest can also exploit an insecure virtual environment and spread the attack across several networks.

These attacks can occur due to:

- Insecure **operating systems** like older versions of Windows, which do not have modern security features such as protection against **poison cookies**, memory **address layout randomization** and hardened stack
- VM traffic to and from an external network utilizes the **two-layer bridge**, where all traffic passes through the same set of network interface cards (**NICs**). An attacker may overload the switch, and in order to preserve its performance, the switch pushes all data packets out on its ports. This action makes it a **dumb hub**, with no security usually offered by a switch.

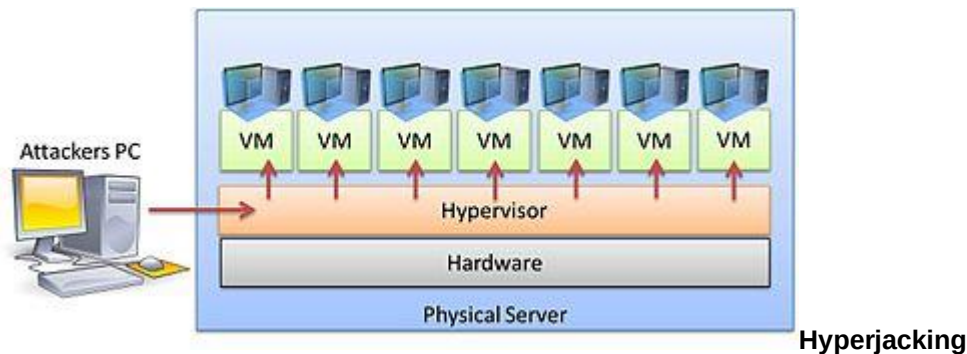
Virtual machine hyper jumping can be **prevented** using various methods, including:

- Grouping and separating the uplinks to separate the Web-facing traffic from the database traffic and prevent the database server from directly accessing the internal network
- Using private VLANs to hide the VMs from one another and only allow the guest machines to talk to the gateway
 - Using **the latest and most secure operating systems** with up-to-date security patches

Hyperjacking

Hyperjacking is an attack in which a [hacker](#) takes malicious control over the [hypervisor](#) that creates the virtual environment within a [virtual machine](#) (VM) host. The point of the attack is to target the operating system that is below that of the virtual machines so that the attacker's program can run and the applications on the VMs above it will be completely oblivious to its presence.

Overview



Hyperjacking involves installing a malicious, fake [hypervisor](#) that can manage the entire server system. Regular security measures are ineffective because the [operating system](#) will not be aware that the machine has been compromised. In hyperjacking, the hypervisor specifically operates in **stealth mode** and runs beneath the machine, it makes it more difficult to detect and more likely to gain access to computer servers where it can affect the operation of the entire institution or company. If the hacker gains access to the hypervisor, everything that is connected to that server can be manipulated. The hypervisor represents a single point of failure when it comes to the security and protection of sensitive information.

For a hyperjacking attack to succeed, an attacker would have to take control of the hypervisor by the following methods:

- Injecting a rogue hypervisor beneath the original hypervisor
- Directly obtaining control of the original hypervisor
- Running a rogue hypervisor on top of an existing hypervisor

Mitigation techniques

Some basic design features in a virtual environment can help mitigate the risks of hyperjacking:

- Security management of the hypervisor must be kept separate from regular traffic. This is a more network related measure than hypervisor itself related.
- Guest operating systems should never have access to the hypervisor. Management tools should not be installed or used from guest OS.
- Regularly patching the hypervisor.

Known attacks

As of early 2015, there had not been any report of an actual demonstration of a successful hyperjacking besides "proof of concept" testing. The VENOM vulnerability (CVE-2015-3456) was revealed in May 2015 and had the potential to affect many datacenters. Hyperjackings are rare due to the difficulty of directly accessing hypervisors; however, hyperjacking is considered a real-world threat.

On September 29, 2022, Mandiant and VMware jointly made public their findings that a hacker group has successfully executed malware-based hyperjacking attacks in the wild, affecting multiple target systems in an apparent espionage campaign. In response, Mandiant released a security guide with recommendations for hardening the VMware ESXi hypervisor environment.

SubVirt: Implementing malware with virtual machines.

Attackers and defenders of computer systems both strive to gain complete control over the system. To maximize their control, both attackers and defenders have migrated to low-level, operating system code.

In this case, we propose a new type of malicious software which gains qualitatively more control over a system. This new type of malware, which we call a **hypervisor**, installs a virtual-machine monitor underneath an existing operating system and hoists the original operating system into a virtual machine.

Hyperviruses are hard to detect and remove because their state cannot be accessed by software running in the target system. Further, hyperviruses support general-purpose malicious services by allowing such services to run in a separate operating system that is protected from the target system.

We explore this new threat by implementing two prototype hyperviruses. We use our prototype hyperviruses to subvert Windows XP and Linux target systems, and we implement four example malicious services using the hypervisor platform. Last, we use what we learn from our prototype hyperviruses to explore ways to defend against this new threat.

Blue Pill (software)

Blue Pill is the codename for a rootkit based on x86 virtualization. Blue Pill originally required AMD-V (Pacifica) virtualization support, but was later ported to support Intel VT-x (Vanderpool) as well. It was designed by Joanna Rutkowska and originally demonstrated at the Black Hat Briefings on August 3, 2006, with a reference implementation for the Microsoft Windows Vista kernel.

The name is a reference to the red pill and blue pill concept from the 1999 film *The Matrix*.

Overview

The Blue Pill concept is to trap a running instance of the operating system by starting a thin **hypervisor** and virtualizing the rest of the machine under it. The previous operating system would still maintain its existing references to all devices and files, but nearly anything, including hardware interrupts, requests for data and even the system time could be intercepted (and a fake response sent) by the hypervisor. The original concept of Blue Pill was published by another researcher at IEEE Oakland in May 2006, under the name VMBR (virtual-machine based rootkit).^[1]

Rutkowska claims that, since any detection program could be fooled by the hypervisor, such a system could be "100% undetectable". Since AMD virtualization is seamless by design, a virtualized guest is not supposed to be able to query whether it is a guest or not. Therefore, the only way Blue Pill could be detected is if the virtualization implementation were not functioning as specified.^[2]

This assessment, repeated in numerous press articles, is disputed: AMD issued a statement dismissing the claim of full undetectability.^[3] Some other security researchers and journalists also dismissed the concept as implausible.^[4] Virtualization could be detected by a timing attack relying on external sources of time.^[5]

In 2007, a group of researchers challenged Rutkowska to put Blue Pill against their rootkit detector software at that year's Black Hat conference,^[6] but the deal was deemed a no-go following Rutkowska's request for \$384,000 in funding as a prerequisite for entering the competition.^[7] Rutkowska and Alexander Tereshkin countered detractors' claims during a subsequent Black Hat speech, arguing that the proposed detection methods were inaccurate.^[8]

The source code for Blue Pill has since been made public,^{[9][10]} under the following license: *Any unauthorized use (including publishing and distribution) of this software requires a valid license from the copyright holder. This software has been provided for the educational use only during the Black Hat training and conference.*^[11]

Red Pill

Red Pill is a technique to detect the presence of a virtual machine also developed by [Joanna Rutkowska](#).^[12]

The Vitriol VM Rootkit is Unguarded

'Vitriol machine-based rootkits' make malware-hiding even stronger and can while command a target operating system.

Every innovation is accompanied with a drawback, sometimes caustic in nature. A 'virtual machine rootkit' that can convert Windows into a 'virtual machine' (VM) was put before the audience at Microsoft's recent 'Blue Hat Hacker Conference'. Dino Dai Zovi, a security specialist developed this rootkit named 'Vitriol'. This rootkit uses Virtualization Technology (VT-x) of Intel (VT-x was formerly known as 'Vanderpool').

'Vitriol' compromises a system by playing the host Operating System after transforming the actual host operating system into a guest OS, all without the PC user's knowledge. The Windows or Linux, once converted into a VM, can neither detect the rootkit nor remove it. The group delivered a presentation at the 'Black Hat Conference', Las Vegas.

The 'Vitriol rootkit' is capable of transforming a running operating system into a 'hardware virtual machine' and load itself as a 'rootkit hypervisor'. The malware then gets beyond access of the operating system, spreading stealth and becoming more treacherous. Virus scanners and rootkit tracers become helpless in protecting systems against such rootkits. Also, Vista's new 'PatchGuard' and 'driver signature kernel' protection, too, cannot function for '4-bit systems'.

Virtualization extensions of CPU supported by hardware like Intel's VT-x permit simultaneous running of multiple OS and without alterations on same processor. The extensions are extremely helpful to multiple-operating systems computing, as they also offer useful abilities to rootkit creators.

'Virtual machine rootkits' have emerged in the past too. Developers at 'Microsoft Research' and the 'University of Michigan' have authored a 'VM-based rootkit' called "SubVirt". It is impossible to detect this rootkit because the security software running in the infected system just cannot access it.

The popularity of VMs is growing. Its benefits are numerous while the drawbacks are numbered. One of the problems is related to the high cost of acquiring hardware to push up VM power.

The ongoing progress in developing ways to wrongfully seize VM technology for stealthy and treacherous purposes is definitely active, which requires security professionals to make inroads outpacing the culprits.

ATTACKS OF VIRTUALIZATION

Virtualization, which reduces expenses and provides IT flexibility to organizations, also has security risks. These risks can be broken down into three categories: attacks on virtualization infrastructure, attacks on virtualization features, and compliance and management challenges, according to the ISACA white paper virtualization benefits and challenges. There are two primary types of attacks all virtualization

infrastructure: hyper jacking and virtual machine jumping. **HYPER JACKING**

Hyper jacking is still a theoretical attack scenario, but it has earned significant media attention because of the damage it could cause. **VIRTUAL MACHINE JUMPING** It is an attack method exploits the hypervisor's weakness that allows a virtual machine to be accessed from another.

Management challenges

Performance issues—often created by a move from physical hardware to virtual hardware—and VM saturation cause application networking resources to be depleted at a much faster rate. I/O intensive operations get bogged down in the virtualization translation layer.

The Benefits Of Virtualization

Attacks on Virtualization features and compliance and Management challenges.

Cost Reduction: Partitioning and isolation, the characteristics of server virtualization, enable simple and safe server consolidation. Through consolidating, the number of physical servers can be greatly reduced. This alone brings benefits such as reduced floor space, power consumption, and air conditioning costs. However, it is essential to note that even though the number of physical servers is greatly reduced, the number of virtual servers to be managed does not change. Therefore, when virtualizing servers, the installation of operation management tools for efficient server management is recommended. Server consolidation with virtualization reduces costs of hardware, maintenance, power, and air conditioning. In addition, it lowers the Total Cost of Ownership (TCO) by increasing the efficiency of server resources and operational changes, as well as virtualization-specific features. As a result of today's improved server CPU performance, a few servers have high resource usage rates but most are often underutilized. Virtualization can eliminate such ineffective use of CPU resources, plus optimize resources throughout the server environment. Furthermore, because servers managed by each business division's staff can be centrally managed by a single administrator, operation management costs can be greatly reduced.

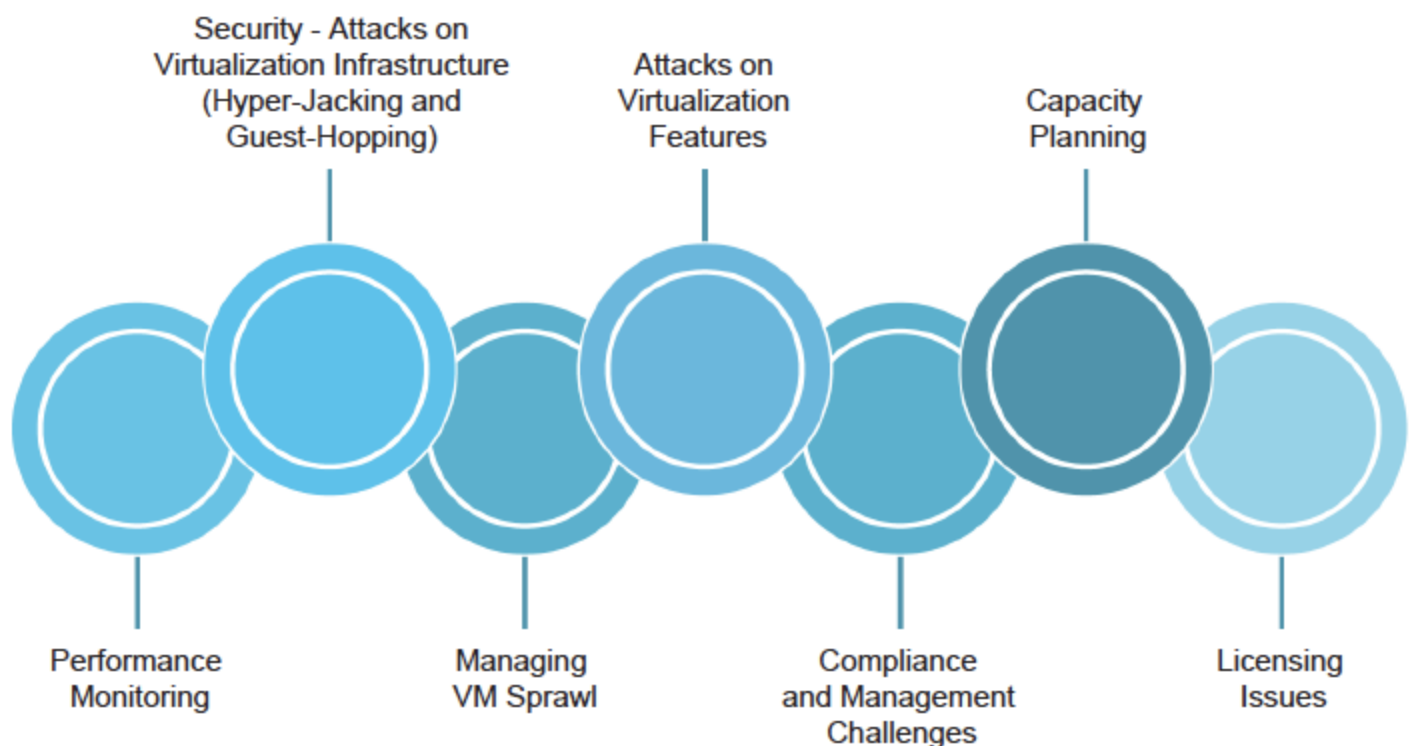
Improves Provisioning Speed: What once took hours can now be done in minutes. Not only can new servers be brought online quickly, but they can be broken down, rearranged, reassigned, and redeployed to suit the needs of the moment.

Improves Availability and Business Continuity: One beneficial feature of virtualized servers not available in physical server environments is live migration. With live migration, virtual servers can be migrated to another physical server for tasks such as performing maintenance on the physical servers without shutting them down. Thus, there is no impact on the end-user. Another great advantage of virtualization technology is that its encapsulation and hardware-independence features enhance availability and business continuity.

Increases Efficiency for Development and Test Environments: At system development sites, servers are often used inefficiently. When different physical servers are used by each business division's development team, the number of servers can easily increase. Conversely, when physical servers are shared by teams, reconfiguring development and test environments can be time-consuming. Such issues can be resolved by using server virtualization to simultaneously run various operating system environments on one physical server, thereby enabling concurrent development and test of multiple environments. In addition, development and test environments can be encapsulated and saved, because reconfiguration is extremely simple.

Greater Flexibility: Virtualization allows you to run multiple types of applications and operating systems on the same hardware. You can configure a virtualized environment to support different operating systems for workstations, and run nearly any application to any machine.

The Challenges Of Virtualization



Performance Monitoring: Unlike physical servers, monitoring the performance of the virtual servers requires a different approach. Conventional CPU and memory utilization monitoring don't work. In a virtual

infrastructure, the VMs share the common hardware resources such as CPU, memory, and storage. If a host has hundreds of VMs, each of the VMs shares a certain percentage of these resources, the data processing works in tandem. To ensure the performance of a virtual infrastructure, a different set of performance metrics has to be monitored. Metrics such as CPU ready, memory ready, memory balloon, and swapped memory have to be monitored across all the VMs in real-time. In addition, live migration of VMs increases the monitoring complexity.

Security – Attacks on Virtualization Infrastructure (Hyper-Jacking and Guest-Hopping): In virtualized systems, the hypervisor is the single point of failure in security and if you lose it, you lose the protection of sensitive information. This increases the degree of risk and exposure substantially. For example, hyper-jacking involves installing a rogue hypervisor that can take complete control of a server. Regular security measures are ineffective because the operating system will not even be aware that the machine has been compromised. Pro-active (rather than reactive) measures such as hardening the environment are required. So the best way to avoid hyperjacking is to use hardware-rooted trust and secure launching of the hypervisor. VM jumping or guest-hopping is a more realistic possibility and poses just as serious a threat. This attack method typically exploits vulnerabilities in hypervisors that allow malware or remote attacks to compromise VM separation protections and gain access to other VMs, hosts or even the hypervisor itself. These attacks are often accomplished once an attacker has gained access to a low-value, thus less secure, VM on the host, which is then used as a launch point for further attacks on the system. Some examples have used two or more compromised VMs in collusion to enable a successful attack against secured VMs or the hypervisor itself.

Managing VM Sprawl: Since virtualization brought in the power of easily allocating the storage space to VMs, it led to both the uncontrolled growth of virtual machines as well as the overallocation of resources. In a typical virtual infrastructure, all of the available VMs are not used to full capacity, which wastes available resources. Hence, VM sprawl has become the Achilles' heel to virtualization. To avoid VM sprawl, the virtual infrastructure has to be monitored continuously to identify VMs that are idle for a certain period, VMs that have resources overprovisioned or under-provisioned, and VMs that are not even powered on since they were provisioned. By removing such unused VMs – or optimizing the resources allocated to VMs – virtual sprawl can be greatly minimized. Resource optimization also avoids needless hardware purchases.

Attacks on Virtualization Features: Although there are multiple features of virtualization that can be targeted for exploitation, the more common targets include VM migration and virtual networking functions. VM migration, if done insecurely, can expose all aspects of a given VM to both passive sniffing and active manipulation attacks.

Compliance and Management Challenges: Compliance auditing and enforcement, as well as day-to-day system management, are challenging issues when dealing with virtualized systems. VM sprawl and even dormant VMs will make it a challenge to get accurate results from vulnerability assessments, patching/updates, and auditing.

Capacity Planning: Virtual infrastructure acts as the backbone of data centers that power today's businesses. As a business grows, it is necessary to expand its underlying infrastructure also. Without proper capacity planning, the server management team will have a hard time scaling the infrastructure to meet business demands. Capacity planning also requires constant monitoring of the virtual infrastructure. A trend on the resource consumption by the VMs has to be identified and should be projected over a period of time. This helps the server administrator to understand the current trend and plan how many resources have to be added to handle the future load.

Licensing Issues: Software vendors license virtualization in different ways. Unfortunately, there is no industry standard for applying metrics to virtual scenarios. Some software companies try to ignore the issue and remain in the physical realm, while others create conversion models based on peak resource use or running instances. For example, one organization was running seven virtual instances on a server with four physical cores. Depending on which software they were using, they required seven licenses from one vendor

– but only four from another.

Top Threats to Cloud Security, Strategies and counter measures for addressing Virtualization risks.

Virtual machine sprawl is the uncontrolled spread of VMs created for specific workloads and then abandoned after serving their purpose. This unchecked proliferation can lead to VMs with sensitive information being compromised because they are not being actively managed and updated.

Top Threats to Cloud Security, Strategies and counter measures for addressing Virtualization risks.

-Explain Concept

Virtual machine sprawl is the uncontrolled spread of VMs created for specific workloads and then abandoned after serving their purpose. This unchecked proliferation can lead to VMs with sensitive information being compromised because they are not being actively managed and updated.

Access Controls

An attacker gaining access to your virtual infrastructure, whether via physically accessing host servers or via a compromised user account on your management platform, can cause a lot of damage to your systems.

Search our Knowledge Base

Search

Top Eight Virtualization Security Issues and Risks

Posted on December 15, 2021 by Marho Atumu

Category: Other | Tags: Security, Virtual Machines, Virtualization,

Virtualization as a concept is experiencing more utility in recent times due to its ability to offer improved efficiency and scalability while reducing costs. Over 90% of businesses use server virtualization, and more organizations have begun exploring other types of virtualization, including desktop, application, and storage virtualization.

However, this increased adoption of virtualization has also led to increased concerns about the security risks associated with virtualization.

Is Virtualization a Security Risk?

Virtualization has some clear security advantages when compared to traditional server infrastructure. These advantages include the improved availability that comes with virtual machines (VMs), the isolation of these VMs from the operating systems and physical hardware they run on, and the enhanced security tools that come with most virtualization solutions.

However, this improved security posture doesn't mean that virtualization has no security risks. The fact that many businesses employ this technology makes it a valid target for hackers and other malicious actors.

It's safe to say that virtualization is no more (or less) of a security risk than other parts of your information technology infrastructure, and with increased adoption comes the need for awareness of the potential issues that IT administrators may face.

Virtualization Security Issues and Risks

1. VM Sprawl

Virtual machine sprawl is the uncontrolled spread of VMs created for specific workloads and then abandoned after serving their purpose. This unchecked proliferation can lead to VMs with sensitive information being compromised because they are not being actively managed and updated.

2. Malware & Ransomware Attacks

Virtual machines are also susceptible to viruses, malware, and ransomware attacks. These attacks can come from infected VM images or from users without proper security training. Once a VM is infected, it can spread malware across the entire virtual infrastructure without adequate isolation and security controls.

3. Network Configuration

There is a lot of work involved in managing multiple virtual machines, even with a VM management solution like VMware vSphere. Making poor configuration choices, like allowing file sharing between VMs, or leaving unused firewall ports open could be all that's needed for a hacker to gain access to your virtual infrastructure. This misconfiguration can also include the physical servers, which can become a security risk without the latest security patches and firmware.

4. Access Controls

An attacker gaining access to your virtual infrastructure, whether via physically accessing host servers or via a compromised user account on your management platform, can cause a lot of damage to your systems.

5. Security of Offline Virtual Machines

Offline or offsite backups are an essential part of disaster recovery planning. However, any VMs you back up offline are stuck with their security updates and configurations from when they were last online. This lack of updates will make such a VM a security risk to the rest of your virtual environment when it is time to come back online.

6. Workloads with Different Trust Levels

Without proper security controls, it's easy to create a test server that should be in a low trust zone, on the same physical hardware as a live production server with sensitive information that requires a high trust zone.

7. Hypervisor Security Controls

The hypervisor is the platform that makes it possible to run virtual machines. Therefore, it can become a single point of failure for your entire virtual infrastructure without proper security measures to mitigate the risk of attacks.

8. Cloud Service Provider APIs

For organizations that run a hybrid implementation involving public and private cloud infrastructure, intrusion attempts via APIs from your cloud service providers are a potential risk. These APIs are meant for effective communication between your virtual environment and the cloud-hosted one, and if they are not adequately secured, a data breach may occur.

Virtualization Security Best Practices

Now that we've outlined the potential risks that come with virtualization, it's time we cover the ways to mitigate these risks effectively. Here are some steps you can take to reduce your exposure to the security risks outlined above:

Create policies and procedures to govern the management of virtual machines throughout their lifecycle, from creation to deletion. You can use a cybersecurity framework as a guideline for these policies, but they must be adapted to suit your organization's unique needs.

Be sure to enforce the encryption of all offline VM images and backups to protect the confidentiality of the information stored on them and the integrity of the images.

Implement access control systems for the physical environment where you host your infrastructure and the hypervisor/VM management platform. Only administrators and authorized users should have access.

Use a VM management solution, like VMware vSphere. These tools can effectively maintain your entire virtual infrastructure to ensure proper resource allocation for VMs, and automated installation of security

patches and updates.

Implement a monitoring and logging system for all network traffic and VM operations and regularly audit these logs to identify trends that may point to a breach.

If your virtual environment involves an external cloud services provider (CSP), ensure that your connection to CSP services is encrypted and uses a private channel separate from regular Internet traffic.

Module-II

Introduction to Cloud Security

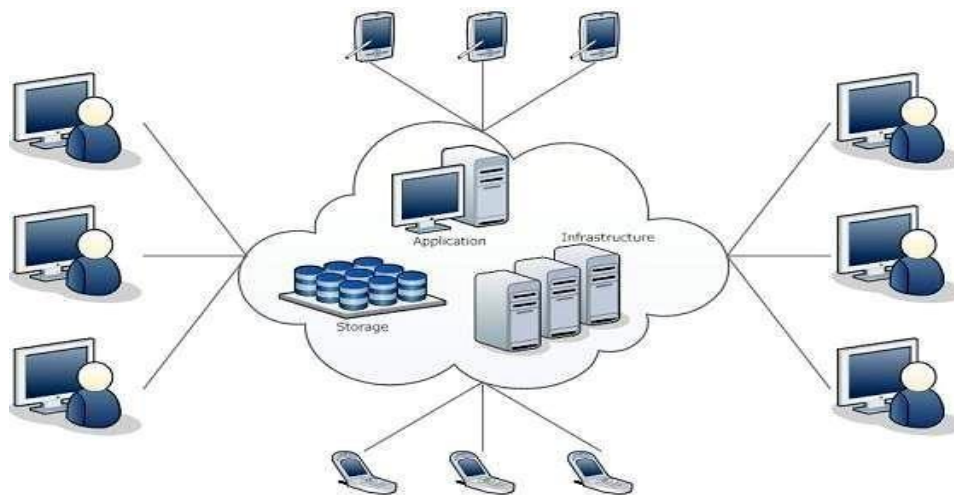
What is Cloud?

The term **Cloud** refers to a **Network** or **Internet**. In other words, we can say that Cloud is something, which is present at remote location. Cloud can provide services over public and private networks, i.e., WAN, LAN or VPN.

Applications such as e-mail, web conferencing, customer relationship management (CRM) execute on cloud.

What is Cloud Computing?

Cloud Computing refers to **manipulating, configuring, and accessing** the hardware and software resources remotely. It offers online data storage, infrastructure, and application.

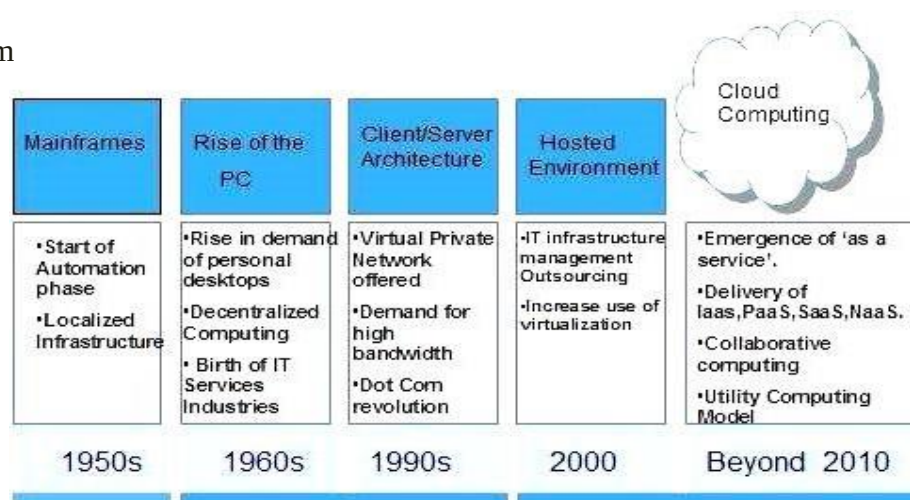


Cloud computing offers **platform independency**, as the software is not required to be installed locally on the PC. Hence, the Cloud Computing is making our business applications **mobile** and **collaborative**.

History of Cloud Computing

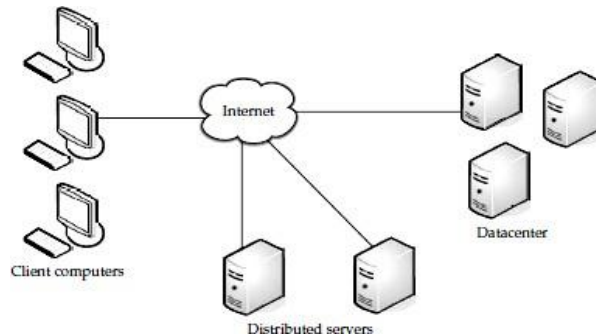
The concept of **Cloud Computing** came into existence in the year 1950 with implementation of mainframe computers, accessible via **thin/static clients**. Since then, cloud computing has been evolved from static clients to dynamic ones and from software to services.

The following diagram explains the evolution of cloud computing:



Components of Cloud Computing

In a simple, topological sense, a cloud computing solution is made up of several elements: clients, the datacenter, and distributed servers. These components make up the three parts of a cloud computing solution. Each element has a purpose and plays a specific role in delivering a functional cloud based application, so let's take a closer look.



1. Clients:

Clients are, in a cloud computing architecture, the exact same things that they are in a plain, old, everyday local area network (LAN). They are, typically, the computers that just sit on your desk. But they might also be laptops, tablet computers, mobile phones, or PDAs—all big drivers for cloud computing because of their mobility. Anyway, clients are the devices that the end users interact with to manage their information on the cloud.

Clients generally fall into three categories:

- **Mobile:**
Mobile devices include PDAs or smartphones, like a Blackberry, Windows Mobile Smartphone, or iPhone.
- **Thin:**
Clients are computers that do not have internal hard drives, but rather let the server do all the work, but then display the information.
- **Thick:**
This type of client is a regular computer, using a web browser like Firefox or Internet Explorer to connect to the cloud.

Thin clients are becoming an increasingly popular solution, because of their price and effect on the environment. Some benefits to using thin clients include

- **Lower hardware costs:**
Thin clients are cheaper than thick clients because they do not contain as much hardware. They also last longer before they need to be upgraded or become obsolete.

- **Lower IT costs:**
Thin clients are managed at the server and there are fewer points of failure.
- **Security:**
Since the processing takes place on the server and there is no hard drive, there's less chance of malware invading the device. Also, since thin clients don't work without a server, there's less chance of them being physically stolen.
- **Data security:**
Since data is stored on the server, there's less chance for data to be lost if the client computer crashes or is stolen.
- **Less power consumption:**
Thin clients consume less power than thick clients. This means you'll pay less to power them, and you'll also pay less to air-condition the office.
- **Ease of repair or replacement:**
If a thin client dies, it's easy to replace. The box is simply swapped out and the user's desktop returns exactly as it was before the failure.
- **Less noise:**
Without a spinning hard drive, less heat is generated and quieter fans can be used on the thin client.

2. Data centre:

The *data center* is the collection of servers where the application to which you subscribe is housed. It could be a large room in the basement of your building or a room full of servers on the other side of the world that you access via the Internet.

A growing trend in the IT world is virtualizing servers. That is, software can be installed allowing multiple instances of virtual servers to be used.

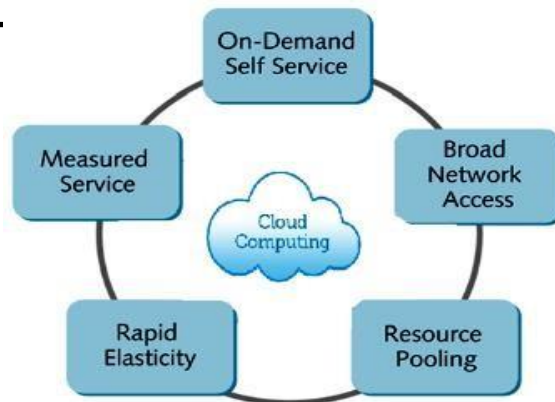
In this way, you can have half a dozen virtual servers running on one physical server.

3. Distributed Servers:

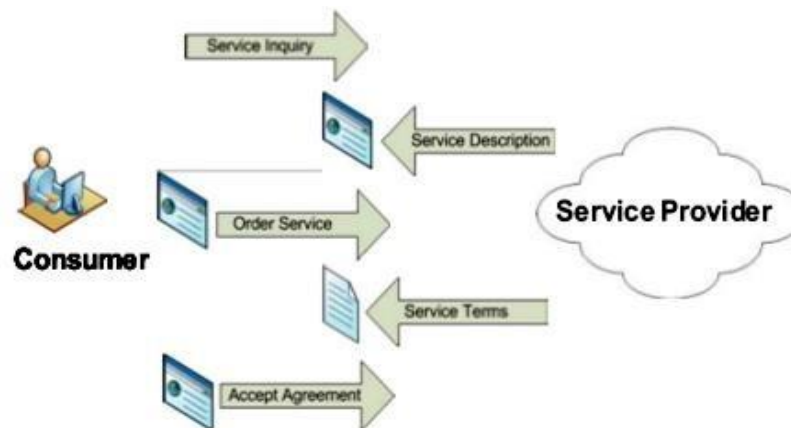
But the servers don't all have to be housed in the same location. Often, servers are in geographically disparate locations. But to you, the cloud subscriber, these servers act as if they're humming away right next to each other. This gives the service provider more flexibility in options and security.

For instance, Amazon has their cloud solution in servers all over the world. If something were to happen at one site, causing a failure, the service would still be accessed through another site.

Also, if the cloud needs more hardware, they need not throw more servers in the safe room—they can add them at another site and simply make it part of the cloud.



On-demand self-service: A consumer can unilaterally provision computing capabilities, such as server time and network storage, as needed automatically without requiring human interaction with each service provider.



1. **Broad network access:** Capabilities are available over the network and accessed through standard mechanisms that promote use by heterogeneous thin or thick client platforms (e.g., [mobile](#) phones, tablets, laptops and workstations).



2. **Resource pooling:** The provider's computing resources are pooled to serve multiple consumers using a multi-tenant model, with different physical and virtual resources

3. dynamically assigned and reassigned according to consumer demand. There is a sense of location independence in that the customer generally has no control or knowledge over the exact location of the provided resources but may be able to specify

Architecture influence

Architectural Influences

The realization of cloud computing was affected by a number of architectural developments over the past decades. These influences range from advances in high-performance computing to scaling and parallelism advances. Some of the principal architectural developments that support cloud computing are summarized in the following sections.

High-Performance Computing

The computers known as supercomputers evolved during the 1960s. In 1961, IBM developed the IBM 7030 “Stretch,” which was the first transistor-based supercomputer. It was built for the Los Alamos National Laboratory and was specified at 1.2 MFLOPS (million floating-point operations per second.).

In general, a Beowulf architecture has the following characteristics:

- ☐ It is designed for parallel computing.
- ☐ Client nodes are usually diskless, dumb terminals.
- ☐ Client nodes are connected to a server node through a network, such as Ethernet and Ethernet switches.
- ☐ It uses Parallel Virtual Machine (PVM) software, which enables multiple networked computers to appear as a single parallel processor.
- ☐ It uses open-source operating systems such as Linux or Solaris.
- ☐ It incorporates the Message Passing Interface (MPI) API specification, which enables multiple computers to communicate to form a cluster.

Table 1-2: High-Performance Computing Evolution

COMPUTER	YEAR	PERFORMANCE	COMMENTS
Cray-1	1976	250 MFLOPS	Used integrated circuits and incorporated around 200,000 logic gates. The first Cray-1 was delivered to Los Alamos National Laboratories.
Cray X-MP	1983	941 MFLOPS	A Cray Research parallel vector processor supercomputer, which used multiple processors.
Cray-2	1985	1.9 GFLOPS	Successor to Cray X-MP; used an inert liquid cooling system.
Thinking Machines CM-5	1993	60 GFLOPS	A Connection Machine model (arrangement of thousands of connected microprocessors) using massively parallel processing and message-passing, distributed memory.
Intel Paragon XP/S	1993	143 GFLOPS	Incorporated the Intel i860 RISC microprocessor.
IBS ASCI White	2000	7.226 TFLOPS	A computer cluster comprising 512 interconnected IBM commercial RS/6000 SP computers.
NEC Earth Simulator	2002	35.86 TFLOPS	Comprises 640 supercomputers connected by a high-speed network. Each supercomputer contains eight vector processors with a peak performance of 8 GFLOPS.
IBM Blue Gene/L	2007	478.2 TFLOPS	Based on IBM Power Architecture; deployed at Lawrence Livermore National Laboratories.
IBM Roadrunner	2008	1.105 PFLOPS	The world's fastest computer, located at the Los Alamos National Laboratory. It incorporates both AMD 64 dual-core Opteron server processors and an IBM Cell accelerator processor that is connected to each Opteron core.

Utility and Enterprise Grid Computing

The grid as a utility is based on SOA and provides resources using a “payas- you-go” utility model. According to Grid Computing from Sun Microsystems (<http://www.sun.com/servers/grid/>), “Grid Utility Computing is a pay-per-use service that lets users dynamically provision computing power, depending on application requirements.”

An enterprise grid can serve a conventional or virtual organization. A virtual organization can use loosely coupled resources located in a number of geographic locations under different management. An enterprise grid also provides use of a wide variety of IT services such as storage, printers, computers, applications, and databases as needed throughout the enterprise. The enterprise grid will register, manage, provision, provide security for, and bill for these types of services as needed. Enterprise grid and utility computing are best implemented by employing standards and virtualization, which can provide the basis for offering SaaS services for customers. Some existing standard languages and protocols that support enterprise grid and utility computing are the Simple Object Access Protocol (SOAP), Extensible Markup Language (XML), Universal Description, Discovery, and Integration (UDDI), Web Services Description Language (WSDL), and the Open Grid Services Interface (OGSI).

Enterprise grid and utility computing, if implemented and managed properly,
can result in the following benefits:

- ☐ Increased productivity
- ☐ Increased collaboration and improved communications
- ☐ Improved flexibility
- ☐ Virtual organizations that can share resources
- ☐ Ability to scale up and back
- ☐ Rapid and increased access to a variety of computing resources

-
- ☐ Reduction of effort required to manage multiple, non-integrated systems
 - ☐ Increased resiliency and security

Autonomic Computing

The goal of autonomic computing is to provide complex, heterogeneous systems with self-diagnosis, self-healing, and self optimizing capabilities.

Autonomic computing can be defined in architectural terms as follows:

- ☐ Managing systems to the specified requirements without extensive and detailed personnel involvement.
- ☐ Extending and reducing system capabilities rapidly.
- ☐ Managing systems of increasing complexity.
- ☐ Managing complex systems at lower cost.
- ☐ Adapting a system to new technologies.
- ☐ Incorporating systems applications management drivers.

Service Consolidation

Consolidation and sharing of services developed as a cost-effective tool to provide these services over a network, as needed. This capability depended on advances in standardization, optimization, service orientation, and virtualization. In particular, virtualization supports dynamic pools of resources such as servers and storage. Integration of services such as SaaS into the cloud paradigm on a pay-per-use basis provides organizations with attractive alternatives to in-house solutions. The decreasing costs of cloud computing hardware has made shared, consolidated services even more desirable today.

Service consolidation and utilization must also take into account the Quality of Service (QoS), compliance, security, governance, and exit strategy issues that arise with cloud computing. Also, at the enterprise level, the access of external cloud services should ensure their federation into the enterprise network.

Horizontal Scaling

In general, scalability is the property exhibited by a system or service where in an increase of resources results in improved performance proportional to the additional amount of resources.

Scaling can be implemented in both centralized and distributed systems. In centralized systems, vertical scaling, or scaling up, is accomplished by increasing the size or capability of existing or fewer resources. In distributed systems, such as those used in cloud computing, horizontal scaling is the addition of more of the individual resource elements, such as servers. In addition to providing improved performance, horizontal scaling is used to implement redundancy and reliability of loosely coupled systems. Thus, distributed systems are more resilient and can tolerate failures of some resource units. This ability to reliably effect horizontal scaling is an important factor in the success of cloud computing. Generally, vertical scaling is easier to implement, but it is more expensive. In addition, there is the possibility of a single point of failure. Horizontal scaling is usually less costly and more resilient, but it's relatively more difficult to implement than vertical scaling. Horizontal scaling is particularly applicable to Web 2.0 in that, as applications expand, there is a corresponding decrease in performance. Because most applications are data intensive in cloud computing, significant improvements in performance can be achieved by horizontally scaling the database. This scaling involves replicating the database across multiple servers. Some Web 2.0 horizontal database scaling approaches include the following:

□ **Caching**—Lowering application response times by performing memory caching of heavily accessed

data using horizontally scaled, dedicated cache servers to reduce the load on application servers.

Table-level partitioning—Slicing data horizontally and distributing the data across database instances

□ **Sharding**—Managing a growing number of applications by dividing datasets into smaller elements across many physical servers and segregating the transactional bandwidth across these servers.

Web Services

The World Wide Web Consortium (W3C) (<http://www.w3.org/TR/ws-gloss/>) defines a Web service as “a software system designed to support interoperable machine-to-machine interaction over a network. It has an interface described in a machine-process able format (specifically WSDL). Other systems interact with the Web service in a manner prescribed by its description using SOAP-messages, typically conveyed using HTTP with an XML serialization in conjunction with other Web-related standards.”

The Web Services Descriptive Language (WSDL), referred to in the Web service definition is “an XML format for describing network services as a set of endpoints operating on messages containing either document-oriented or procedure oriented information. The operations and messages are described abstractly, and then bound to a concrete network protocol and message format to define an endpoint. Related concrete endpoints are combined into abstract end points(services). WSDL is extensible to allow description of endpoints and their messages regardless of what message formats or network protocols are used to communicate.”

The Simple Object Access Protocol (SOAP), also cited in the Web service definition, is “a lightweight protocol for exchange of information in a decentralized, distributed environment. It is an XML-based protocol that consists of three parts: an envelope that defines a framework for describing what is in a message and how to process it, a set of encoding rules for expressing instances of application-defined data types, and a convention for representing remote procedure calls and responses.

In summary, a Web service uses a standard interface that is described in WSDL to provide communication among computing platforms running different applications, with the SOAP XML-based protocol supporting this exchange of information over HTTP.

High-Scalability Architecture

A number of options are available to promote high scalability. One approach, for example, would be to incorporate dynamically scalable CPUs and pipelining the processing of queued tasks. These options and additional possibilities are summarized in Figure 1-2.

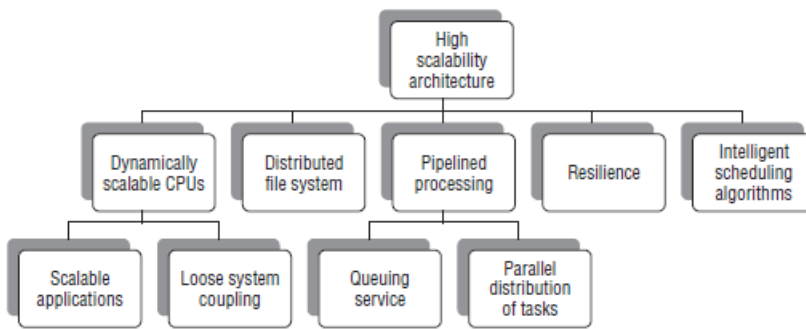


Figure 1-2: High-scalability architecture options

Technology influence

Universal Connectivity

Cloud computing requires universal access and connectivity to the Internet to thrive. In the United States, the economic stimulus bill of 2009 provided billions of dollars to expand and improve the nation's high-speed network infrastructure. Cloud computing serves consumers and organizations by ubiquitous connectivity among customers, businesses, and government organizations through avenues such as Web services, peer-to-peer exchanges, and Web 2.0. This universal connectivity should be accomplished through high-speed, broadband networks that do not provide different capabilities to different users on a selective basis.

Commoditization

Prior to the 1980s, computer systems were proprietary and many had their own unique hardware, software, and protocols. With the rise of the PC in the 1980s, some software and hardware components became standardized and interchangeable among platforms. In the 1990s, the emphasis on local area networks (LANs) and wide area networks (WANs) led to commonality in communications protocols and eventually the Internet, which further accelerated commoditization. Organizations such as CompuServe and Prodigy with proprietary technologies gave way to the falling cost of bandwidth and the flexibility and accessibility provided by the World Wide Web. Strong drivers in the path toward commoditization are open-source software such as FireFox and OpenOffice, and the rapidly falling costs of servers, PCs, PDAs, and multifunction cellular products.

On the way to cloud commoditization, if it does occur, the industry will coalesce around one or two standards that support interoperability and interchange of services among cloud vendors. These standards can be formal, de facto, or open. De facto standards might arise from their use by dominant vendors, such as Amazon or VMware, which promote the Elastic Compute Cloud (EC2) application programming interface (API) and the vCloud API, respectively.

Excess Capacity

Excess capacity in the context of cloud computing has two interpretations. One refers to cloud-consuming organizations having to meet peak service demands on an intermittent basis, such as for a

holiday season; the other denotes an organization offering cloud computing to generate revenue from

its excess server, storage, or database capacity.

By using cloud computing to meet peak demands, an organization can invoke the “pay as you go” model and not have to incur the costs of unused capacity in local hardware, including depreciation, power, personnel, and software. This model is best executed if the excess capacity requirements in an organization are predictable and can be integrated into an organization’s IT resource planning.

Conversely, excess capacity in the cloud can be considered an advantage for a cloud provider, and used to service many organizations, thus making the cloud environment more efficient by spreading costs over multiple consumers. Thus, fewer resources are required to serve a variety of clients, which results in the conservation of energy and capital. This reasoning would apply to both private and public clouds.

Open-Source Software

Open-source software has a place in cloud computing, but that place can take various forms and elicits different opinions. The use of open-source software in cloud computing can provide the following benefits:

- ☐ Availability and access to source code
- ☐ No license fees
- ☐ Ease of adoption for first-time users
- ☐ Ease of development and integration of new applications
- ☐ Ability to modify, extend, and redistribute software
- ☐ No payment for patches and upgrades
- ☐ Open file formats
- ☐ Avoidance of vendor lock-in
- ☐ Low barriers for new users to try the software

Table 1-3: Open-Source Cloud Platforms

SOURCE	PLATFORM	COMMENT
University of Chicago (http://workspace.globus.org)	Globus Nimbus	Supports developing a computing cluster that supports an Infrastructure-as-a-Service (IaaS) cloud incorporating the Xen hypervisor
University of California, Santa Barbara; Eucalyptus Systems (http://www.eucalyptus.com/)	Eucalyptus	Supports the installation of on-premise private and hybrid clouds using the existing hardware and software
European Union/IBM (http://www.reservoir-fp7.eu/)	RESERVOIR (Resources and Services Virtualization without Barriers)	Provides for the large-scale deployment of IT services across multiple, different administrative domains
Enomoly (www.enomaly.com/)	Enomalism	Supports the creation of cloud capacity and management of virtual machines
Abiquo (www.abiquo.com/)	Abicloud	Infrastructure software for development and management of public and private clouds
Xen (www.Xen.org)	Xen Cloud Platform (XCP)	Cloud infrastructure platform for delivery of customizable, multi-tenant cloud services

Virtualization

Traditionally, server virtualization was viewed as a cost-saving measure. However, it has evolved to the point that it is now considered to have value both in providing flexibility in the utilization of resources and as an enabler of cloud computing. Some of the key benefits of virtualization that are indigenous to cloud computing are as follows:

- ☐ ☐ Billing based on usage (utility pricing) and not fixed hardware capacity
- ☐ ☐ Rapid deployment of additional servers
- ☐ ☐ Promotion of economies of scale
- ☐ ☐ Separation of the customer from physical server locations
- ☐ ☐ Usage based on service-level agreements
- ☐ ☐ Alternative sourcing supported
- ☐ ☐ Fault tolerance
- ☐ ☐ Application mobility among servers and data centers.

Virtualization provides a **level of freedom** of choice for the customer, and efficiencies and cost savings for cloud providers. In many instances, the migration to virtualized clouds will be initially through hybrid clouds as customers test and evaluate the cloud paradigm in the context of their own business requirements.

Virtualization also supports **utility computing** in that a cloud can enable a customer to open virtual

machines on the cloud provider's resources as if the virtual instance were running on the customer's hardware. This capability can be extremely useful in meeting a customer's expected and unexpected peak demands.

Operational influence

Operations considerations have a significant effect on the deployment, management, Maintenance, and selection issues associated with cloud computing.

Consolidation

Virtualization offers a means to consolidate applications and servers, and changes the traditional relationship between software and hardware.

Virtualization enables more than one application to run on a server and the capability to distribute multiple applications over multiple servers for resiliency. This consolidation increases resource utilization, boosts efficiency, lowers capital investment and maintenance costs, and provides the basis for increased security.

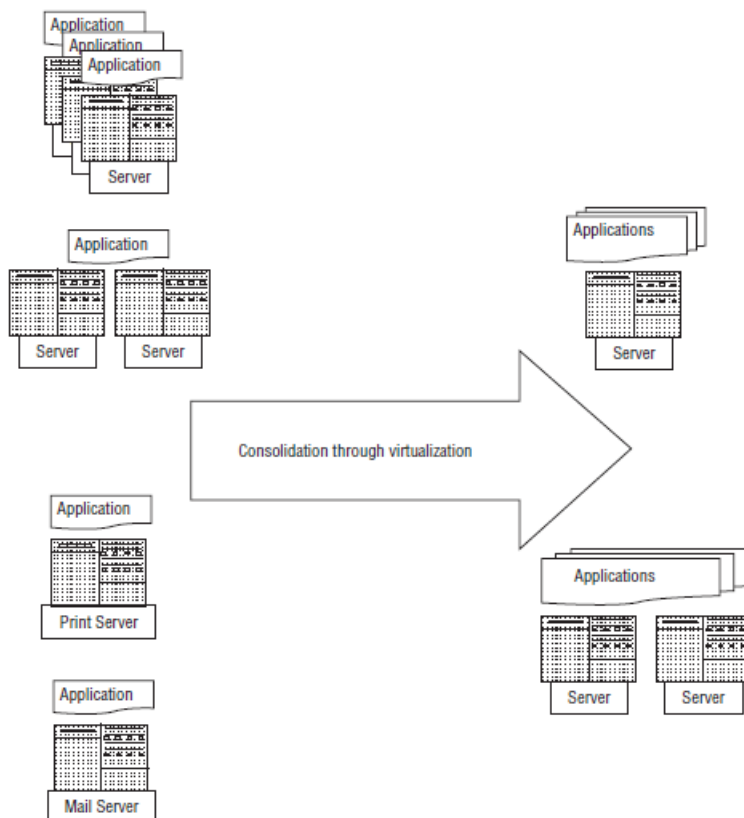


Figure 1-3: Server consolidation through virtualization

To achieve effective consolidation, it is important to understand the resources that are necessary to run the application over time. This data includes the application's usage characteristics, peak resource requirements, and performance when approaching or exceeding resource capacity. With this information, the virtual machines that will run the applications can be allocated across the physical computing and storage resources. Improper allocations can result in performance problems when

applications' resource requirements vary widely over time.

Design an effective consolidation strategy that takes into account the impact of consolidating applications on the key observable characteristics of execution, including resource utilization,

performance, and energy consumption.

Consolidation methods must carefully decide which workloads should be combined on a common physical server because workload resource usage, performance, and energy usages are not additive.

There exists an optimal performance and energy point, which changes with acceptable degradation in performance and application mix.

The optimal performance and energy point should be tracked as workloads change to improve energy-efficient consolidation.

Outsourcing

Cloud computing offers opportunities for cost savings, increased efficiency, agility, and flexible billing options through outsourcing. The large investments of cloud providers in developing high-capability infrastructures eliminate the need for customers to make large initial or additional upfront expenditures for in-house IT systems.

Some of the key benefits of outsourcing

- ☐ Resiliency
- ☐ Disaster recovery
- ☐ Economy of scale
- ☐ Security
- ☐ Automatic and continuous hardware and software upgrades
- ☐ Libraries of applications
- ☐ Performance monitoring and management
- ☐ Rapid capability expansion
- ☐ Rapid capability downsizing
- ☐ Significant energy savings

An important activity that should accompany an outsourcing decision is the development and implementation of a long-term plan to improve business processes and the corresponding employment of computing platforms. This planning process should evaluate the impact of outsourcing on the organization.

Outsourcing Legal Issues

Organizations have to ensure that contracts with cloud vendors provide the protections and legal guarantees that are specific to the organization's mission and operations.

Service-level agreements (SLAs)—A SLA should be entered into with mutual understanding and commitment from both the customer and the cloud provider. The service provider should have a clear

understanding of the customer's expectations and concerns. The following elements are typically included in a SLA:

- ☐ Application security
- ☐ Intellectual property protection
- ☐ Termination
- ☐ Compliance requirements

- ☐ Customer responsibilities
- ☐ Performance tracking
- ☐ Problem resolution
- ☐ Termination
- ☐ Lead time for implementation

Regulatory issues—A contract between a cloud provider and customer should require the provider to adhere to the legal requirements of public privacy laws.

Customer privacy—Customer information resident on a cloud provider's platforms can be subject to aggregation and data mining. Vendors must provide guarantees that personally identifiable information will be protected and not used for monetary gain, such as selling the information to advertisers.

Termination—The provisions for the customer or cloud provider to terminate the contractual agreement or temporarily halt usage should be specified, along with any required notification lead times.

☐ **Identity protection**—The cloud service customer should require the vendor to provide mutually agreed upon guarantees that the vendor will protect personally identifiable information from compromises that might result in the theft of an individual's identity for the purposes of credit fraud.

☐ **Patent issues**—The cloud vendor should warrant that they are the rightful and legal owners of the technologies they are providing and that they will indemnify the customer against any patent infringement situations that may arise.

☐ **Selection of jurisdiction**—The customer of the cloud provider usually specifies that the jurisdiction in the contract be that of the customer.

Export issues—The cloud service provider should ensure that it complies with relevant export control laws that prohibit some types of encryption software to be stored or transmitted outside of a country. This situation might occur if a cloud provider has data centers located outside a nation's boundaries.

Business Process Outsourcing (BPO) Issues.

In business process outsourcing, an organization outsources business activities such as finance, benefits, customer service, accounting, and payroll functions.

Business processes that are obtained in a user's country are known as onshore Outsourcing, whereas those services that are contracted from a foreign country are described as offshore outsourcing. BPO widely employs vendors in nations such as India, China, and Malaysia.

Financial services—These services include expense processing, transaction processing, decision support, and capital equipment management.

☐ **Human resources (HR) functions**—HR functions include benefits, employee information management, recruiting, payroll, customer-service call centers, and application development.

☐ **Supply chain management (SCM)**—Management of the organization's supply chain involves coordinating among customers, partners, and suppliers, and includes procuring, managing payments, logistics support, operations management, and developing evaluation metrics.

An organization that is considering BPO must understand the following:

- ☐ What Web services are available
- ☐ Integration of data and services
- ☐ Possible reuse of existing applications
- ☐ Use of shared and/or open-source solutions
- ☐ Roles of IT staff in providing cloud engagement services.

Some additional benefits of BPO are as follows:

- ☐ Market advantage from technology and process improvements
- ☐ Improved regulatory compliance
- ☐ Lowered procurement costs
- ☐ Enhanced integration of acquisitions
- ☐ Global perspectives

A category related to BPO is knowledge processing outsourcing (KPO). KPO is a mode of outsourcing that requires special knowledge and expertise. KPO includes activities such as R&D and new product development that involves particular skills or abilities.

IT Service Management

IT service management is the application of best practices to the oversight and operation of delivered computing services. This activity is best implemented through a set of processes that support the

following functions:

Fault tolerance—To provide availability of needed resources

☐ Visibility—To monitor performance and make required adjustments and improvements

☐ Security—To provide acceptable risk levels and meet compliance Requirements

☐ Control—To manage virtualized resources across shared platforms

☐ Automation—To maintain performance and security and reduce costs of managing complex computing environments

☐ Performance—To meet committed requirements of customers and incorporate optimization to reduce operating costs

Automation

The ability to automatically manage and transport virtual applications dynamically is a key characteristic of effective cloud computing. Cloud automation provides the means to build processes that provision cloud services across virtual and physical cloud platforms. Cloud automation technologies should typically provide the following capabilities.

Resiliency by automatic failover to other cloud platforms

☐ Triggers that respond to external occurrences to adjust cloud resource allocations to meet compliance and SLA requirements

☐ Management of the transition of development programs from prototype to test to commissioning across virtual platforms

☐ Provisioning to adjust to load demands and provide agility in assigning resources

☐ Management of resources based on SLAs and policies

☐ Monitoring of virtual machine–related data, such as storage usage, utilization history, owners, and file system access history

☐ General data collection and reporting, including change reporting

☐ Enforcement of security restrictions regarding directories and configuration Elements

- Monitoring security and privacy violations

An emerging trend to support configuration of the automation requirements is the use of rule-based tools. These tools enable users to create rules that can specify triggers, set maximum and minimum windows for certain metrics, define SLA boundaries, and implement other runtime information acquisition routines.

Cloud Delivery Models

The SPI Framework

The generally agreed upon classification scheme for cloud computing has been coined the **Software-Platform-Infrastructure (SPI) model**. This acronym represents the three major services provided through the cloud: SaaS, or Software as a Service; PaaS, Platform as a Service; and IaaS, Infrastructure as a Service.

1.0 — As ISPs originally began to provide Internet services, dial-up modem service for homes and organizations proliferated, making the Internet a commercial commodity.

2.0 — During a period of merging and consolidation, ISPs began offering other services, such as e-mail and off-site data storage.

3.0 — The increasing demand for infrastructure to host their customers' applications and data led to the creation of data centers known as collocation facilities, where multiple customers could centralize their servers, storage, and communications systems on the ISP's premises.

4.0 — The commoditization of collocation facilities led to the development of application service providers (ASPs). ASPs provided software applications tailored to an organization, owning both the application and the infrastructure.

5.0 — The ASP model eventually evolved into cloud computing, which brought new delivery models, such as the SPI framework, with its SaaS, PaaS, and IaaS service models, and various deployment models, such as private, community, public, and hybrid cloud models.

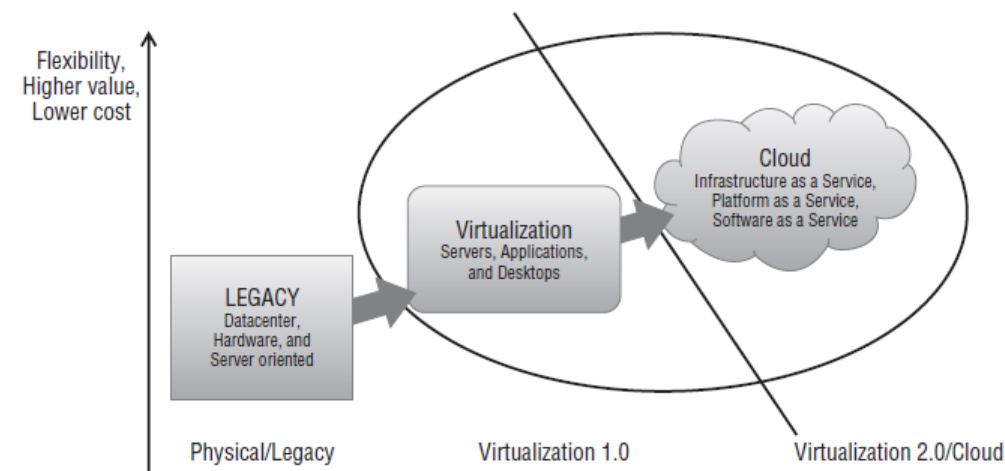


Figure 2-1: SPI evolution through virtualization

The SPI Framework vs. the Traditional IT Model

A traditional enterprise-wide application rollout requires resources and coordination from many parts of the organization. This rollout may require numerous new hardware (servers, perimeter network devices, workstations, backup systems, operating systems, communication link provisioning, and user and management training).

Typically organizations employing the SPI framework don't own the infrastructure that hosts the software application. They instead license application usage from the cloud provider, by employing

either a subscription-based license or a consumption-oriented model. This enables companies to pay for only the resources they need and use, and to avoid paying for resources they don't need, thus helping them avoid a large capital expenditure for infrastructure.

SPI FRAMEWORK SERVICE	DESCRIPTION	VENDOR EXAMPLE
IaaS	Shared Internet infrastructure, such as servers and storage	Amazon EC2 and S3, Sun Microsystems Cloud Services, Terremark, Dropbox
PaaS	Application platform that provides developers with quick deployment	Google App Engine, force .com (from salesforce.com), Microsoft Azure
SaaS	Stateless cloud-enabled multiple-instance applications on a pay-per-use pricing model	Zoho Suite, Apple's MobileMe, Google Docs

- **SaaS (Software as a Service)** – Least extensibility and greatest amount of security responsibility taken on by the cloud provider
- **IaaS (Infrastructure as a Service)** – Greatest extensibility and least amount of security responsibility taken on by the cloud provider
- **PaaS (Platform as a Service)** – Lies somewhere in the middle, with extensibility and security features that must be leveraged by the customer."

Cloud Software as a Service (SaaS)

Software as a Service (SaaS) solutions deliver software applications over the Web. A SaaS provider deploys software to the user on demand, commonly through a licensing model. The provider may host the application on its own server infrastructure or use another vendor's hardware.

The acronym "SaaS" is used for both "Security as a Service" as well as the more common "Software

as a Service.” In this text, “SaaS” refers to “Software as a Service” unless “Security as a Service” is specifically noted.

Benefits of the SaaS Model

It enables the organization to outsource the application hosting to an independent software vendor (ISV) or other software service provider.

This almost always reduces the cost licensing, management hardware, and other resources required to internally host the app.

Cloud Platform as a Service (PaaS)

PaaS is similar to SaaS, but the service is an entire application development environment, not just the use of an application. PaaS solutions differ from SaaS solutions in that they provide a cloud-hosted virtual development platform, accessible via a Web browser.

The PaaS vendor provides several services for application developers:

- ☐ A virtual development environment
- ☐ Application standards, usually based on the developers’ requirements
- ☐ Toolkits configured for the virtual development environment
- ☐ A ready-made distribution channel for public application developers.

The PaaS model provides a lower cost of entry for application designers and distributors, by supporting the complete software development life cycle (SDLC) of the Web app, thereby eliminating the need for the acquisition of hardware and software resources.

In order for a software development platform to be considered a true PaaS solution, several elements need to be present:

- ☐ Baseline monitoring of application usage should be used to effect platform Process improvement.
- ☐ The solution should provide seamless integration with other cloud resources, such as Web-based databases and other Web-based infrastructure components and services.
- ☐ Dynamic **multi-tenancy** must be achievable, and collaboration via the cloud between developers, clients, and users throughout the SDLC should be easily achievable.
- ☐ Security, privacy, and reliability must be maintained as a basic service.
- ☐ The development platform must be browser-based.

Amazon Web Services (AWS) has instituted PaaS services for developers, largely through integration and partnering with AWS, to provide development platforms on top of AWS.

Cloud Infrastructure as a Service (IaaS)

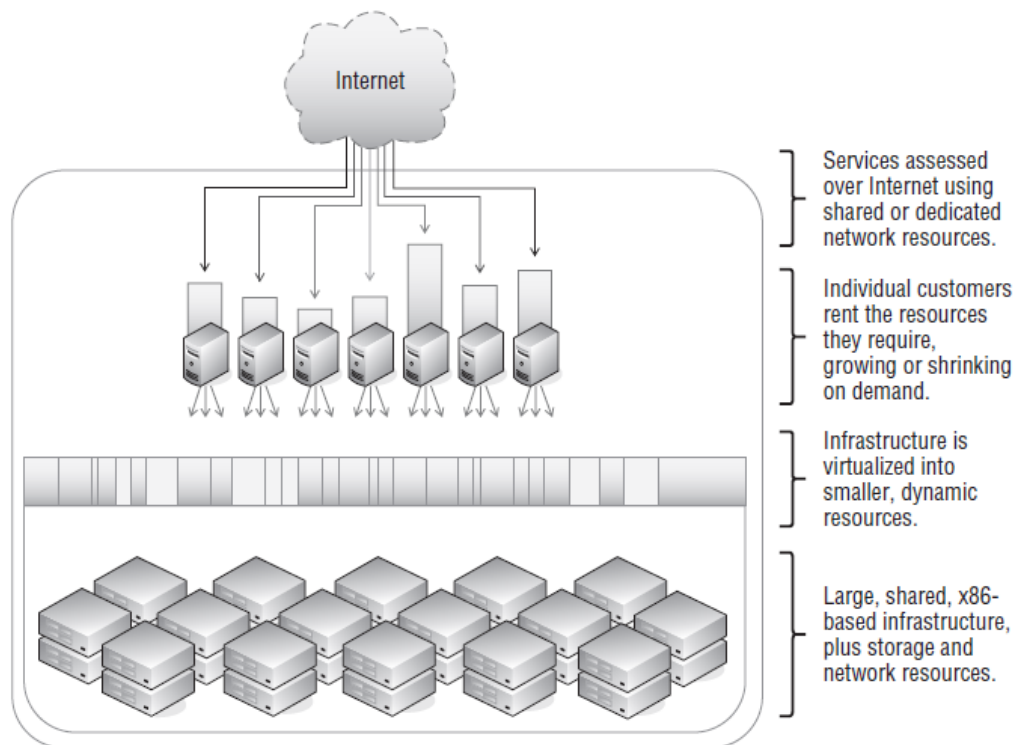
Again, Amazon is in the fore front of cloud computing, offering a large menu of cloud services, especially focused on IaaS:

- ☐ Amazon Elastic Compute Cloud (Amazon EC2) — Virtual computing environment, providing resizable compute capacity in the cloud
- ☐ Amazon SimpleDB — A Web service providing the core database functions of data indexing and

querying in the cloud

- Amazon Simple Storage Service (Amazon S3) — A Web services interface that provides access to scalable and inexpensive data storage infrastructure.
- Amazon CloudFront — Provides a Web service for content delivery
- Amazon Simple Queue Service (Amazon SQS) — Automated workflow service that provides a scalable queue for storing messages as they travel between computers.
- Amazon Elastic MapReduce — Easily and cost-effectively processes vast amounts of data utilizing a hosted Hadoop framework (The Apache Hadoop project develops open-source software for reliable, scalable, distributed computing.).

- Amazon Relational Database Service (Amazon RDS) — A Web service that makes it easy to set up, operate, and scale a relational database in the cloud.



The Cloud Trust Protocol (CTP)

The Cloud Trust Protocol (CTP) is the mechanism by which cloud service consumers (also known as “cloud users” or “cloud service owners”) ask for and receive information about the elements of transparency as applied to cloud service providers. The primary purpose of the CTP and the elements of transparency is to generate evidence-based confidence that everything that is claimed to be happening in the cloud is indeed happening as described, ..., and nothing else. This is a classic application of the definition of digital trust. And, assured of such evidence, cloud consumers become liberated to bring more sensitive and valuable business functions to the cloud, and reap even larger payoffs. With the CTP cloud consumers are provided a way to find out important pieces of information concerning the compliance, security, privacy, integrity, and operational security history of service elements being performed “in the cloud”.



The slide features a dark header with the title "Cloud Trust Protocol (CTP)" in white. Below the header, on the right, is the CTP logo. On the left, a list of five bullet points is presented, each preceded by a blue arrow. The footer of the slide includes the CSA logo on the left, the copyright notice "Copyright © 2011 Cloud Security Alliance" in the center, and the URL "http://www.csa-lln.org/technical/ctp/" on the right.

Cloud Trust Protocol (CTP)

- Developed by CSC, transferred to CSA
- Open standard and API to verify control assertions
- “Question and Answer” asynchronous protocol, leverages SCAP (Secure Content Automation Protocol)
- Integrates with Cloud Audit
- Now we have all the components for continuous controls monitoring

CSA Copyright © 2011 Cloud Security Alliance <http://www.csa-lln.org/technical/ctp/>

Trusted Cloud Initiative (TCI)

The Cloud Security Alliance Trusted Cloud Initiative Working Group has updated its [Reference Architecture research website](#) to include simplified architecture definition results, as well as an interactive application that allows users to learn about the applicability of the TCI reference architecture to their business scenario. **About the Business Scenario Application** You can begin the process of comparing your business scenario against the Reference Architecture [here](#). You will be asked to provide a scenario name and basic information about the scope and model of the business, which will enable the delivery of a suite of questions from the CSA CAIQ Questionnaire. Once you answer the questions, you will receive tailored results about your business scenario.

About the Trusted Cloud Initiative The Trusted Cloud Initiative helps cloud providers develop industry-recommended, secure and interoperable identity, access and compliance management configurations, and practices. The Trusted Cloud Initiative will develop reference models and education in a vendor-neutral manner, inclusive of all CSA members and affiliates who wish to participate. The Trusted Cloud Initiative Reference Architecture is both a methodology and a set of tools that enable security architects, enterprise architects and risk management professionals to leverage a common set of solutions that fulfill their common needs to be able to assess where their internal IT and their cloud providers are in terms of security capabilities and to plan a roadmap to meet the security needs of their business.

What is Security as a Service (SECaaS)?

Security as a Service (SECaaS) can most easily be described as a cloud delivered model for outsourcing [cybersecurity services](#). Much like Software as a Service, SECaaS provides security services on a subscription basis hosted by cloud providers. Security as a Service solutions have become increasingly popular for corporate infrastructures as a way to ease the in-house security team's responsibilities, scale security needs as the business grows, and avoid the costs and maintenance of on- premise alternatives.

Benefits of Security as a Service

Cost Savings

One of the biggest benefits of a Security as a Service model is that it saves a business money. A cloud delivered service is often available in subscription tiers with several upgrade options so a business only pays for what they need, when they need. It also eliminates the need for expertise.

The Latest Security Tools and Updates

When you implement SECaaS, you get to work with the latest security tools and resources. For anti-virus and other security tools to be effective, they must be kept up to date with the latest patches and virus definitions. By deploying SECaaS throughout your organization, these updates are managed for you on every server, PC and mobile device.

Faster Provisioning and Greater Agility

One of the best things about as-a-service solutions is that your users can be given access to these tools immediately. SECaaS solutions can be scaled up or down as required and are provided on demand where and when you need them. That means no more uncertainty when it comes to deployment or updates as everything is managed for you by your SECaaS provider and visible to you through a web-enabled dashboard.

Free Up Resources

When security provisions are managed externally, your IT teams can focus on what is important to your organization. SECaaS frees up resources, gives you total visibility through management dashboards and the confidence that your IT security is being managed competently by a team of outsourced security specialists. You can also choose for your IT teams to take control of security processes if you prefer and manage all policy and system changes through a web interface.

Security as a Service Examples

The range of SECaaS services currently available is vast and offers protection at the most granular level. Some examples include:

- Continuous Monitoring
- Data Loss Prevention (DLP)
- Business Continuity and Disaster Recovery (BC/DR or BCDR)
- Email Security
- Antivirus Management
- Spam Filtering
- Identity and Access Management (IAM)
- Intrusion Protection
- Security Assessment
- Network Security
- Security Information and Event Management (SIEM)
- Web Security
- Vulnerability Scanning

How to Choose a Security as a Service Provider

Handing over the security of your most critical and sensitive business assets is a massive undertaking. Choosing a SECaaS provider takes careful consideration and evaluation. Here are some of the most important considerations when selecting a provider:

- Availability - Your network must be available 24 hours a day and so should your SECaaS provider. Vet out the vendor's SLA to make sure they can provide the uptime your business needs and to know how outages are handled.

- **Fast Response Times** - Fast response times are just as important as availability. Look for providers that offer guaranteed response times for incidents, queries and system updates.
- **Disaster Recovery Planning** - Your provider should work closely with you to understand the vulnerabilities of your infrastructure and the external threats that are most likely to cause the most damage. From vandalism to weather disasters, your provider should ensure your business can recover quickly from these disruptive events.
- **Vendor Partnerships** - A SECaaS provider is only ever as good as the vendors that have forged partnerships with. Look for providers that work with best in class security solution vendors and who also have the expertise to support these solutions.

Whether it is saving money, improving efficiencies or protecting your infrastructure from the latest security threats, managed services like SECaaS can provide great value to your organization by strengthening your defenses and improving your bottom line.

Transparency as a Service (TaaS)

Collecting data behind the scenes to meet key purchasing objectives

Using TaaS, the Purchasing Authority analyzes every supplier quotation against the VaaS or BaaS standards without disruption, while improving quoting cycle times. Additionally, we aggregate information and report progress on key performance indicators for your supply chain. Using TaaS, we centralize cost and performance data for ongoing analysis and optimization.

Monitor Supplier RFP Activity – We review all quoting activity related to the parts identified for the spend, including RFQs sent to the supplier and supplier quote responses. All activity is integrated into Excel for ease of review.

Gather/Cleanse/Format/Consolidate and Analyze Data – We collect volume data to calculate annual savings.

Generate RFQ Financial Evaluation and Report – We identify and consolidate savings opportunities. TaaS provides a program-by-program view of costs and identifies causes of price changes in client-defined categories.

1. Cloud security threats

In September 2012, the European Network and Information Security Agency (ENISA) top threats publication, lists the following threats against cloud computing as emergent and on the increase –

- Code injection and directory traversal
- Drive by exploits
- Information leakage (especially with increased use of mobile devices)
- Insider threats
- Identity theft (especially with increased use of mobile devices)
- Targeted attacks

There is a basic lack of control over cloud-based environments and uncertainty over how to deal with insider threats, compliance duties and mobile access (BCS The Chartered Institute for IT, 2013).

According to the CSA, the notorious nine cloud computing top threats in 2013 in order of severity are:

- Data Breaches
- Data Loss
- Account Hijacking
- Insecure APIs
- Denial of Service
- Malicious Insiders
- Abuse of Cloud Services
- Insufficient Due Diligence
- Shared Technology Issues

Other security threats we identified were:

- Incorrect Hypervisor security implementations in non-private IaaS cloud environments.
- Wrong firewall usages and wrong firewall and access control implementations.
- Predominant use of Vulnerable Distributed Database Systems (DDS).
- Malwares.

The next section will discuss some of the threats listed above under the following headings - Abuse of Cloud Services, Lack of expertise in cloud technology, Inability to guarantee complete data deletion, Message integrity violations, Data leakages, Authentication Issues, Inadequate Monitoring, Insecure interfaces and APIs, Social engineering, drive by exploits and insider threats and Access control violations.

IaaS threats

- **Abuse of cloud services**

Currently, there are no physical interactions in purchasing cloud services and most CSP's do not conduct routine inspection on the activities of their IaaS users due to privacy rules, in cases where the latter does not apply, attackers patterns and strategies change over time making attack discoveries and protection even more difficult. Malicious users with forged or stolen bank details could purchase IaaS cloud services and use them to serve malware or perform phishing attacks against other cloud users, as earlier mentioned, turning the cloud into biggest botnet (Eric et al., 2010). This threat is also applicable in PaaS cloud infrastructure.

- **Lack of expertise in cloud technology**

Research has also shown that there are not enough competent security personnel in securing the volumes of data held in cloud environments. Several cloud security issues have also been attributed to incorrect security configurations in the cloud (BCS The Chartered Institute for IT, 2013) (Nasser, 2013). For instance, (1) defining security configurations on a hypervisor pose a security threat as VMs completely lose their security when they are relocated (Chris, 2011) and (2) the use of DDS API calls are vulnerable to SQL-Injection attacks (Steve, 2011).

PaaS threats

- **Inability to guarantee complete data deletion**

Due to the distributed storage nature of the cloud and collaborations between several cloud service providers (e.g. cloud bursting), guaranteeing the complete deletion of a client's data on the client's request is still an issue. This affects several cloud consumers by causing unwanted vendor lock-ins and privacy issue.

- **Message integrity violations**

Research has shown that some CSPs do not apply sufficient encryption and some do not encrypt all data stored in the cloud due to the overhead of encryption and the inability to process all encrypted data respectively. This has led to message integrity violations which pose a serious security threat to cloud consumer's privacy (Intel IT Centre, 2011). It is also known that the privacy of cloud consumers files stored in the cloud are threatened by deduplication attacks. Malicious users can easily identify other users file; learn the contents of those files as well as save the files in a remote control centre (Danny, Benny and Alexandra, 2010).

SaaS threats

- **Inadequate Monitoring**

As also mentioned earlier, fine grained auditing and traceback is difficult to realise in cloud environments due to shared log files. In networked environments, hardware association could be used to establish traceback however, virtualization makes such association more difficult to establish. Privacy rules also contribute a threat to security as most cloud customers only want their activities to be monitored for charging and accounting purposes only (Sraavan and Upendra, 2010).

Common threats

- **Authentication Issues**

Existing password-based authentication has an inherited limitation, cause several drawbacks and poses significant risks. Trust propagation for an authenticated user's security context between various interoperating clouds is yet to be fully realised within cloud environments.

- **Data leakages**

As mentioned previously, the multi-tenancy characteristic of cloud environments pose a significant data leakage threat. There is a good documentation of breaking out of one VM into another within the same host as well as URL traversal making it possible for a malicious tenant to access other tenant's data. Data leakage during cloud bursting is also common due to heterogeneity between different clouds.

The different security requirements and trust relations for different tenants is thought as to make a multi-tenant cloud a single point of compromise due to complex security and trust issues (Hassan, James and Gail, 2010).

- **Insecure interfaces and APIs**

The cause of most application security issues has been attributed to bad application development practices. Cloud environments also use applications which are built for in-house deployments therefore, suffer from any bugs in such applications too (Carl, 2009) (Sravan and Upendra, 2010) (Steve, 2013). DDS systems such as CouchDB, FlockDB, Hive, MongoDB, RavenDB and SimpleDB use API calls (NoSQL) to perform CRUD operations for applications instead of SQL. There are documentations for vulnerabilities in DDS such as limited support for Dynamic Application Testing Tools (DAST), lack of support for native encryption and hashing, SQL-Injection etc. (Steve, 2011).

- **Social engineering, drive by exploits and insider threats**

The Web is rich with deceptive content that lures users into downloading malware. ENISA and Niels, Moheeb and Panayiotis (2009) express concerns over compromises to cloud servers due to Social engineering attacks, Drive by exploits or Drive-by downloads. Due to the human factor, Social engineering, Drive-by downloads and insider threats still pose a high security threat to cloud computing.

- **Access control violations**

The ability to emulate hardware via software (Virtualisation) is one of the underlying technologies that drive cloud computing. This provides the ability to run several virtual machines (VM) on the emulation software stack (Hypervisor) which creates the possibility for multi-tenancy and the ability to reallocate resources as needed for elasticity and scalability. However, resource reallocation creates the possibility that sectors containing for instance one tenant's deleted files which have moved into other co-tenants VM can be recovered by those co-tenants. In addition, IP addresses of VM or hosts freed during server relocations which are allowed access into the cloud environment may return to public pools and be used by malicious attackers to access a cloud environment. Heterogeneity in cloud access control interfaces is another serious access control security issue. This makes it difficult for organisations to move their access control policies along when the switch cloud service providers.

Table 1: Cloud security threats

CSPs	Security Threats
Carpathia	Lack or immature trust extensions in hypervisors and cloud ecosystem.
Cisco	Lack of cloud standards, inadequate security for cloud automation, lack of automation for security service provisioning, inadequate encryption key management and the overhead of encryption.
Citrix	Administrative mistakes and lack of approved workflow.
Expedient	Insufficient end-to-end chains of trust and inadequate encryption keymanagement.
HyTrust	Inadequate virtualization security, authentication and access control.
McAfee	Distributed data storage problems, access control issues, cloud consumerlock-ins and incomplete data deletion.
OpSource	Constantly changing security requirements and lack of cloud security standards.
Trapezoid	Assurance that data is secure irrespective of its constantly changing location.
Virtustream	Incomplete data deletion, software integrity assurance issues, insufficient data encryption in motion and transference of application authentication.

2. Cloud Security Solutions

There are yet no generally accepted security standards for cloud computing however, some cloud security standards by various organisations like CSA, NIST and FISMA are beginning to have widespread adoption by CSPs. Examples of such standards are the Cloud Control Matrix (CCM) and Security, Trust and Assurance Registry (STAR) created by the CSA. Our research findings show that several CSPs are applying different cloud security solutions, however there are similarities in their usage of security mechanism and appliances. Privacy rules are not in favour of proper cloud consumer activity monitoring however Service Level Agreements (SLA) are now used in creating a balance between the responsibilities and expectations of both the CSP and the cloud service consumer. This goes a long way in alleviating the threat posed by the abuse of cloud computing infrastructure and issues of service availability. Defining security policies in the cloud on host-basis is being used as a solution to the threat of hypervisor security level implementation. The advantage of this is that a security configuration remains with a cloud host as it travels (Chris, 2011). Several organisations and governments have invested in training security experts to combat the incompetency problem amongst cloud security experts (The Chartered Institute for IT, 2013).

Cloud Security Solutions

Carpathia	Lack or immature trust extensions in hypervisors and cloud ecosystem.	Use of modern CPUs and chipsets paired with a policy engine controlling orchestration to allow a chain of trust from the hardware to the hypervisor to the operating system by using modern appliances such as the Intel TXT.
Cisco	Lack of cloud standards, automation problems and inadequate encryption key management.	Standardizations as CSA, (ISO) 27001 and 27002 and FISMA, encryption of all data at rest and in transit. Cisco ASA 5585-X Appliance — Firewall, Cisco IronPort S-Series web security appliance and use of SAML to secure SaaS applications.
Citrix	Administrative mistakes and lack of approved workflow.	Enforcement of a workflow enabled administrative solution.
Expedient	Insufficient end-to-end chains of trust and inadequate encryption key management.	Use of Intel Trusted Execution Technology (Intel TXT). Protection of identity through process and governance.
HyTrust	Inadequate virtualization security, authentication and access control.	2-factor authentication with RSA SecurID or smart cards, root password vaulting, accountability and leveraging any pre-existing investment in LDAP or Microsoft Active Directory.
McAfee	Distributed data storage problems, access control issues, cloud consumer lock-ins and incomplete data deletion.	Cloud Identity Manager which auto-provisions and de-provisions cloud accounts, use of Single-Sign-On, policy-based enforcement and 2-Factor-Authentication.
OpSource	Constantly changing security requirements and lack of cloud security standards.	A combination of SAS 70, PCI, SSAE 16, ISO 27001 27002, FISMA and CSA security standards.
Trapezoid	Assurance that data is secure irrespective of its constantly changing location.	Adoption of SecRAMP Security implementations, use of Intel TXT and Cisco Unified Computing System platform.
Virtustream	Incomplete data deletion, software integrity assurance issues, insufficient data encryption in motion and transference of application authentication.	Encryption of all data at rest using the Intel AES-NI (in the CPU) and encryption of data during transmission.

As a solution to security threats due to Insecure interfaces and APIs, cloud API developers validate and sanitize all inputs both on the client and server side of their source code, encrypt or hash data before inserting them into a DDS and adopt secure software development lifecycle (Nasser, 2013) (Steve, 2013). There is yet no fool-proof approach towards tackling the issues of insider threats but sound physical access control procedures, least privilege access, sanctions and proper security and criminal record checks on cloud security personnel is widely practiced.

The use of distributed application firewalls and application-level proxies implemented inside a perimeter firewall, which are based on decentralized information flow control (DIFC) models that supports a decentralized creation and management of security classes at runtime are being used as solution to access control and trust propagation issues (Jennifer, 2012). Intel TXT has been widely adopted by several CSPs as a solution for trust propagation from the hardware to the hypervisor and to the operating system. Multi- threaded IDS deployed across IaaS, PaaS and SaaS cloud infrastructures have proved effective in mitigating malware attacks in cloud environments. Not until recently did Amazon announce that its Hardware Security Module (CloudHSM) is a solution to the problem of proper digital certificate, encryption and cryptographic key management, but this service is relatively expensive and may be unaffordable by individuals and small firms. With AWS CloudHSM, customers maintain full ownership, control and access to keys and sensitive data while Amazon manages the HSM appliances in close proximity to their applications and data for maximum performance.

Cloud Security Services

Additional factors that directly affect cloud software assurance include authentication, authorization, auditing, and accountability, as summarized in the following sections.

Authentication

Authentication is the testing or reconciliation of evidence of a user's identity. It establishes the user's identity and ensures that users are who they claim to be. For example, a user presents an identity (user ID) to a computer login screen and then has to provide a password. The computer system authenticates the user by verifying that the password corresponds to the individual presenting the ID.

Authorization

Authorization refers to rights and privileges granted to an individual or process that enable access to computer resources and information assets. Once a user's identity and authentication are established, authorization levels determine the extent of system rights a user can hold.

Auditing

To maintain operational assurance, organizations use two basic methods: system audits and monitoring. These methods can be employed by the cloud customer, the cloud provider, or both, depending on asset architecture and deployment.

- ☐ A *system audit* is a one-time or periodic event to evaluate security.
- ☐ *Monitoring* refers to an ongoing activity that examines either the system or the users, such as intrusion detection.

Information technology (IT) auditors are often divided into two types: internal and external. Internal auditors typically work for a given organization, whereas external auditors do not. External auditors are often certified public accountants (CPAs) or other audit professionals who are hired to perform an independent audit of an organization's financial statements. Internal auditors usually have a much

broader mandate than external auditors, such as checking for compliance and standards of due care, auditing operational cost efficiencies, and recommending the appropriate controls.

IT auditors typically audit the following functions:

- System and transaction controls
- ☐ Systems development standards
- ☐ Backup controls
- ☐ Data library procedures
- ☐ Data center security
- ☐ Contingency plans

In addition, IT auditors might recommend improvements to controls, and they often participate in a system's development process to help an organization avoid costly reengineering after the system's implementation.

An *audit trail or log* is a set of records that collectively provide documentary evidence of processing, used to aid in tracing from original transactions forward to related records and reports, and/or backward from records and reports to their component source transactions. Audit trails may be limited to specific events or they may encompass all of the activities on a system.

Audit logs should record the following:

- ☐ The transaction's date and time
- ☐ Who processed the transaction

At which terminal the transaction was processed

- Various security events relating to the transaction

In addition, an auditor should examine the audit logs for the following:

- Amendments to production jobs
- Production job reruns
- Computer operator practices
- All commands directly initiated by the user
- All identification and authentication attempts
- Files and resources accessed

Accountability

Accountability is the ability to determine the actions and behaviors of a single individual within a cloud system and to identify that particular individual. Audit trails and logs support accountability and can be used to conduct postmortem studies in order to analyze historical events and the individuals or processes associated with those events. Accountability is related to the concept of *nonrepudiation*, wherein an individual cannot successfully deny the performance of an action.

NIST 33 Security Principles

Some of the 33 principles that are most applicable to cloud security policies and management are as follows:

- Principle 1 — Establish a sound security policy as the “foundation” for design.
- Principle 2 — Treat security as an integral part of the overall system design.
- Principle 3 — Clearly delineate the physical and logical security boundaries governed by associated security policies.
- Principle 6 — Assume that external systems are insecure.
- Principle 7 — Identify potential trade-offs between reducing risk and increased costs and decreases in other aspects of operational effectiveness.
- Principle 16 — Implement layered security; ensure there is no single point of vulnerability.
- Principle 20 — Isolate public access systems from mission-critical resources (e.g., data, processes, etc.).
- Principle 21 — Use boundary mechanisms to separate computing systems and network infrastructures.
- Principle 25 — Minimize the system elements to be trusted.
- Principle 26 — Implement least privilege.
- Principle 32 — Authenticate users and processes to ensure appropriate access control decisions both within and across domains.
- Principle 33 — Use unique identities to ensure accountability.

Secure Cloud Software Testing

Secure cloud software testing involves a number of activities. Each activity is based on a formal standard or methodology and adds unique value to the overall secure software testing process. An organization typically selects testing activities based on a number of factors, including secure cloud software requirements and available resources. Analyses of test results form the basis for assessing risk to cloud information and means of remediation. Standards and methodologies such as the International Organization for Standardization (ISO) 9126 Standard for Software Engineering/Product Quality, the Systems Security Engineering Capability Maturity Model (SSE-CMM) and the Open Source Security Testing Methodology Manual (OSSTMM) provide additional guidance for secure software evaluation and mitigation. After software has been modified, regression testing provides assurance that the original software system functionality and security characteristics are not negatively affected by the respective changes.

Conformance Testing

The National Institute of Standards and Technology (NIST) states that “conformance testing activities assess whether a software product meets the requirements of a particular specification or standard.”¹⁷ These standards are typically well regarded and widely accepted, such as those from the International Organization for Standardization (ISO), the Institute of Electrical and Electronics Engineers, Inc. (IEEE), or the American National Standards Institute (ANSI). They reflect a commonly accepted “reference system” whose standards recommendations are sufficiently defined and tested by certifiable test methods. They are used to evaluate whether the software product implements each of the specific requirements of the standard or specification.

Conformance testing methodologies applicable to cloud services have been developed for operating system interfaces, computer graphics, documented interchange formats, computer networks, and programming language processors. Most testing methodologies use test case scenarios (e.g., abstract test suites, test assertions, test cases), which themselves must be tested.

Functional Testing

In functional testing, a cloud software application is tested at runtime to determine whether it conforms to its functional requirements. Requirements that state how the application should respond when a specific event occurs are referred to as *positive requirements*. Typically, a positive requirement is mapped to a specific software artifact meant to implement that requirement. This provides traceability from requirements to implementation and informs the tester of which code artifact to test to validate the expected functionality.

An example of a positive requirement is “the application should lock the user account after three failed login attempts.” A tester can validate the expected functionality (the lockout) by attempting to log in to the application three times with the same username and incorrect passwords.

Performance Testing

In an online report (<http://vote.nist.gov/vvsg-report.htm>), NIST states that “what distinguishes performance testing from functional testing is the form of the experimental result. A functional test yields a yes or no verdict, while a performance test yields a quantity.” Performance testing measures how well the cloud software system executes according to its required response times, throughput, CPU, usage, and other quantifiable features in operation. The quantity resulting from a test may subsequently be reduced to a yes or no verdict by comparison with a benchmark.

Performance testing is also commonly known by other names and/or associated with other testing activities, such as stress testing, capacity testing, load testing, volume testing, and benchmark testing. These various performance testing activities all have approximately the same goal: “measuring the cloud software product under a real or simulated load.” Typically, performance testing is conducted late in the software life cycle when the software is fully developed. In order to obtain accurate measurements, the cloud software is deployed and tested in an environment that simulates the operational environment. This can be achieved by creating a cloud “staging” environment, essentially a mirror copy of the production infrastructure, and simulating typical operating conditions.

- **Throughput** — The rate at which the system processes transactions, commonly measured in bytes per second
- **Processing delay** — The time it takes to process those transactions, measured in seconds
- **Load** — The rate at which transactions are submitted to a software product, measured in arriving transactions per second.

Security Testing

Security testing should assess the security properties and behaviors of cloud software as it interacts with external entities (human users, environment, other software) and as its own components interact with each other. Security

testing should verify that software exhibits the following properties and behaviors, as summarized from the “Software Security Assurance State-of-the-Art.

- **Its behavior is predictable and secure.**
- **It exposes no vulnerabilities or weaknesses.**
- **Its error and exception handling routines enable it to maintain a secure state when confronted by attack patterns or intentional faults.**
- **It satisfies all of its specified and implicit nonfunctional security requirements.**
- **It does not violate any specified security constraints.**
- **As much of its runtime-interpretable source code and byte code as possible has been obscured or obfuscated to deter reverse engineering.**

A security test plan should be included in the overall cloud software test plan and should define all testing activities, including the following:

- **Security test cases or scenarios**
- **Test data, including attack patterns**
- **Test oracle (if one is to be used), which is used to determine if a software test has passed or failed**
- **Test tools (white box, black box, static, and dynamic)**
- **Analyses to be performed to interpret, correlate, and synthesize the results from the various tests and outputs from the various tools**

Software security testing techniques can be categorized as white box, gray box, or black box:

- **White box** — Testing from an internal perspective, i.e., with full knowledge of the software internals; the source code, architecture and design documents, and configuration files are available for analysis.
- **Gray box** — Analyzing the source code for the purpose of designing the test cases, but using black box testing techniques; both the source code and the executable binary are available for analysis.
- **Black box** — Testing the software from an external perspective, i.e., with no prior knowledge of the software; only the binary executable or intermediate byte code is available for analysis.

Cloud Penetration Testing

A penetration test is a security testing methodology that gives the tester insight into the strength of the target's network security by simulating an attack from a malicious source. The process involves an active analysis of the cloud system for any potential vulnerabilities that may result from poor or improper system configuration, known and/or unknown hardware or software flaws, or operational weaknesses in process or technical countermeasures. This analysis is carried out from the position of a potential attacker, and can involve active exploitation of security vulnerabilities.

Any security issues that are found are presented to the system owner together with an assessment of their impact, and often with a proposal for mitigation or a technical solution. The intent of a penetration test is to proactively determine the feasibility of an attack or to retroactively determine the degree to which a successful exploit has affected the business. It is a component of a full security audit, which includes the following.

- **A Level I, high-level assessment** — A top-down look at the organization's policies, procedures, standards, and guidelines. A Level I assessment is not usually hands-on, in that the system's security is not actually tested.
- **A Level II, network evaluation** — More hands-on than a Level I assessment, a Level II assessment has some of the Level I activities plus more information gathering and scanning.
- **A Level III, penetration test** — A penetration test is not usually concerned with policies. It is more about taking the adversarial view of a hacker, by seeing what can be accomplished, and with what difficulty.

Several factors have converged in the cloud environment to make penetration testing a necessity. The evolution of information technology has focused on ease of use at the operational end, while exponentially increasing the complexity of the computing resources. Unfortunately, the administration and management requirements of cloud systems have increased for several reasons:

- The skill level required to execute a hacker exploit has steadily decreased.
- The size and complexity of the network environment has mushroomed.
- The number of network and cloud-based applications has increased.
- The detrimental impact of a security breach on corporate assets and goodwill is greater than ever. Penetration testing is most commonly carried out within a "black box," that is, with no prior knowledge of the infrastructure to be tested. At its simplest level, the penetration test involves three phases:

1. **Preparation** — A formal contract is executed containing nondisclosure of the client's data and legal protection for the tester. At a minimum, it also lists the IP addresses to be tested and the time to test.
2. **Execution** — In this phase the penetration test is executed, with the tester looking for potential vulnerabilities.
3. **Delivery** — The results of the evaluation are communicated to the tester's contact in the organization, and corrective action is advised. Whether the penetration test is a full knowledge (white box) test, a partial knowledge (gray box) test, or a zero knowledge (black box) test, after the report and results are obtained, mitigation techniques have to be applied to reduce the risk of compromise to an acceptable or tolerable level. The test should address vulnerabilities and corresponding risks to such areas as applications, remote access systems, Voice over Internet Protocol (VoIP), wireless networks, and so on.

Penetration Testing Tools and Techniques

A variety of tools and techniques, including some used by malicious hackers, can be valuable in conducting penetration tests on cloud systems. Some tools, such as Whois and Nslookup, are public software that can help gather information about the target network. Whois is usually the first stop in reconnaissance. With it, you can find information such as the domain's registrant, its administrative and technical contacts, and a listing of their domain servers. Nslookup enables you to query Internet domain name servers. It displays information that can be used to diagnose Domain Name System (DNS) infrastructure and find additional IP addresses. It can also use the MX record to reveal the IP of the mail server.

Another information source is American Registry of Internet Numbers (ARIN). ARIN enables you to search the Whois database for a network's autonomous system numbers (ASNs), network-related handles, and other related point-of-contact information. ARIN's Whois function enables you to query the IP address to find information on the target's use of subnet addressing.

The common traceroute utility is also useful. Traceroute works by exploiting a feature of the Internet Protocol called time-to-live (TTL). It reveals the path that IP packets travel between two systems by sending out consecutive User Datagram Protocol (UDP) packets with ever-increasing TTLs. As each router processes an IP packet, it decrements the TTL. When the TTL reaches zero, the router sends back a "TTL exceeded" Internet Control Message Protocol (ICMP) message to the origin. Thus, routers with DNS entries reveal their names, network affiliations, and geographic locations.

Three basic types of password cracking methods can be automated with tools:

- **Dictionary** — A file of words is run against user accounts. If the password is a simple word, it can be found fairly quickly.
- **Hybrid** — A hybrid attack works like a dictionary attack, but adds simple numbers or symbols to the file of words. This attack exploits a weakness of many passwords: they are common words with numbers or symbols tacked on the end.
- **Brute force** — The most time-consuming but comprehensive way to crack a password. Every combination of character is tried until the password is broken. Some common Web password-cracking tools are:
 - **Brutus** — Brutus is a password-cracking tool that can perform both dictionary attacks and brute-force attacks whereby passwords are randomly generated from a given character. It can crack the multiple authentication types, HTTP (basic authentication, HTML form/CGI), POP3, FTP, SMB, and Telnet.
 - **WebCracker** — WebCracker is a simple tool that takes text lists of usernames and passwords, and uses them as dictionaries to implement basic password guessing.
 - **ObiWan** — ObiWan is a Web password-cracking tool that can work through a proxy. Using word lists, it alternates numeric or alphanumeric characters with roman characters to generate possible passwords.
 - **Burp Intruder** — Burp Intruder is a Web application security tool that can be used to configure and automate attacks. It can be used to test for Web application vulnerabilities to such attacks as buffer overflow, SQL injection, path traversal, and cross-site scripting.
 - **Burp Repeater** — Burp Repeater is a manual tool that can be used to attack Web applications. It operates by supporting the reissuing of HTTP requests from the same window. It also provides a graphical environment to support the manual Web application testing procedures, and complements other tools such as Burp Intruder.

SQL Injection Attack

SQL injection is an example of a class of injection exploits that occur when one scripting language is embedded inside another scripting language. The injection targets the data residing in a database through the firewall in order to alter the SQL statements and retrieve data from the database or execute commands. It accomplishes this by modifying the parameters of a Web-based application.

Cross-Site Scripting (XSS)

Web application attacks are often successful because the attack is not noticed immediately. One such attack exploits the cross-site scripting (XSS) vulnerability. An XSS vulnerability is created by the failure of a Web-based application to validate user-supplied input before returning it to the client system.

Social Engineering

Social engineering describes the acquisition of sensitive information or inappropriate access privileges by an outsider, by manipulating people. It exploits the human side of computing, tricking people into providing valuable information or allowing access to that information.

Regression Testing

As software evolves, new features are added and existing features are modified. Sometimes these new features and modifications “break” existing functionality that is, cause accidental damage to existing software components.

According to the IEEE Software Engineering Body of Knowledge (IEEE610.12-90), regression testing is the “selective retesting of a system or component to verify that modifications have not caused unintended effects.” Regression testing can indicate that software which previously passed the tests no longer does.

- **Poor revision control practices** — The fix was not documented properly or the change was accidentally reversed.

□ **Software brittleness** — The fix for the initial fault was too narrow in scope. As the software ages and the code base grows larger (becoming “legacy” software), new problems emerge relating to the initial fault but are more difficult to fix without negatively affecting other areas of the software.

□ **Repetition of mistakes** — Problematic code is sometimes copied from one area of the software to another; or when a feature is redesigned, the same mistakes are made in the redesign that were made in the original implementation of the feature.

UNIT 3

Cloud delivery models

There are three main cloud service delivery models:

Infrastructure as a service (IaaS) Software as a service (SaaS) Platform as a service (PaaS)

Cloud Deployment Models Multi-cloud: A step further • Multi-cloud allows you to use two or more clouds from different cloud providers. This can be any mix of Infrastructure, Platform, or Software as a Service (IaaS, PaaS, or SaaS). • With multi-cloud, you can decide which workload is best suited to which cloud-based on your unique requirements.

Identity management and access control

Identity management—also referred to as identity and access management (IAM)—is the overarching discipline for verifying a user's identity and their level of access to a particular system.

Within that scope, both authentication and access control—which regulates each user's level of access to a given system—play vital roles in securing user data.

We interact with authentication mechanisms every day. When you enter a username and password, use a PIN, scan your fingerprint, or tap your bank card, your identity is being verified for authentication purposes. Once your identity is verified, access control is implemented to determine your level of access. This is important for applications and services that have different levels of authorization for different users. Access control, for instance, will allow software administrators to add users or edit profiles while also barring lower-tier users from accessing certain features and information.

Governance and enterprise risk in cloud

Governance and risk management are incredibly broad topics. This guidance focuses on how they change in cloud computing; it is not and should not be considered a primer or comprehensive exploration of those topics outside of cloud.

For security professionals, cloud computing impacts four areas of governance and risk management:

- *Governance* includes the policy, process, and internal controls that comprise how an organization is run. Everything from the structures and policies to the leadership and other mechanisms for management.

Enterprise risk management includes managing overall risk for the organization, aligned to the organization's governance and risk tolerance. Enterprise risk management includes all areas of risk, not merely those concerned with technology.

Key factors to consider autonomic security for cloud application.

Autonomic cloud computing is the distribution of computing resources over the cloud, and it has self-managing features. These systems are capable of adapting to unpredictable changes. While functioning, these autonomic cloud computing systems are capable of hiding built-in intricacies from operators or users as required.

Autonomic computing was started in 2001. It helped to prevail over the quickly growing complicated management of computing systems. This was responsible for reducing the complexity of future computing systems, both with and without the cloud.

Autonomic clouds have come into view as a result of being relevant because of four self-management characteristics of Autonomic Computing(AC).

Legal and Electronic Discovery in the cloud.

Electronic discovery -- also called e-*discovery* or *ediscovery* -- is the process of obtaining and exchanging evidence in a legal case or investigation. E- discovery is used in the initial phases of litigation when involved parties are required to provide relevant records and evidence related to a case. This process includes obtaining and exchanging electronic data that is sought, located, secured and searched for with the intent of using it as evidence.

E-discovery can be conducted offline on a specific computer, or it can be done on a

network. The data collected in the e-discovery process includes any information that is in an electronic format, including emails, texts and social media posts.

Business continuity management and disaster recovery in cloud.

When you deploy assets into the cloud, you can't assume the cloud will always be there, or always work the way you expect. A key point is that the very nature of virtualizing resources into pools typically creates less resiliency for any single asset, like a virtual machine. On the other hand, abstracting resources and managing everything through software opens up flexibility to more easily enable resiliency features like durable storage.

There is a huge range of options here, and not all providers or platforms are created equal, but you shouldn't assume that "the cloud" as a general term is more or less resilient than traditional infrastructure. This is why it is typically best to re-architect deployments when you migrate them to the cloud.

Some points to keep in mind:

- Understand and leverage the platform's BC/DR features before adding on any additional capabilities through third-party tools.

Unit – 4

ITIL lifecycle

IT services have lifecycles just like processes and products. In the best practices of ITIL service management, service lifecycles are defined to describe the process of how services are initiated and maintained. Without these ITIL lifecycles, services can not be implemented and managed with optimal efficiency and efficacy. **It is important to adhere to the principles of the ITIL lifecycles for IT services to run smoothly.** The ITIL lifecycle for services is designed into five stages. These stages are interlinked. The reason behind this is to ensure that the end goal is always kept in mind during all the stages of the ITIL lifecycle for services. This interlinked system is designed to enable consistent IT services.

Securing Data in the Cloud

To secure the data in your cloud, you must consider the security of data in all states – at rest, in transit, and in storage – and who is responsible. The shared responsibility model has become a paradigm that defines interactions with cloud resources and who is responsible for data security.

The use of proper encryption and key management solutions within AWS, Azure, and Google Cloud are the two critical areas of data security in the cloud. For industry resources about data security in the cloud, learn more here:

- [Encrypting Data in AWS](#)
- [Azure's Data Security Best Practices](#)
- [Trusting Your Data on Google Cloud](#)

Securing the Operating System

No matter the operating system that your cloud provider supports, maintenance, proper configurations, and patching methods can strengthen the security of that operating system. Scheduling maintenance windows, staying current with system configuration requirements, and establishing a patch baseline are integral components to cloud security and something your organization must be vigilant in implementing, especially given the current cyber climate where malicious individuals and organizations are quick to exploit vulnerabilities. For more industry resources about security operating systems, learn more here.

Security management functions available for SPI cloud delivery models.

IT security management consists of processes to enable organizational structure and technology to protect an organization's IT operations and assets against internal and external threats, intentional or otherwise. These processes are developed to ensure confidentiality, integrity, and availability of IT systems. Various aspects to IT security in an organization need to be considered. These include security policies and procedures, security organization structure, IT security processes, and rules and regulations.

Security policies and procedures are essential for implementing IT security management: authorizing security roles and responsibilities for various security personnel, setting rules for expected behavior from users and security role players, setting rules for business continuity plans, and more. The security policy should be generally agreed to by most personnel in the organization and have support from high-level management. This helps prioritize at the overall organization level. The IT security processes are essentially part of an organization's risk management processes and business continuity strategies. In a business environment marked by globalization, organizations have to be aware of both national and international rules and regulations. Their information security and privacy policies must conform to these rules and regulations.

IaaS Availability management.

IaaS Availability Management:

IaaS Providers Availability Considerations include computing and building Storage Infrastructure. Other services such as account management, a messagequeue service, an identity and authentication service, a database service, a billing service, and monitoring services. Customer Responsibility for the IaaS are to provision and manage the life cycle of virtual servers. To manage the IaaS virtual infrastructure includes Availability of CSP network available, host, storage, and support application infrastructure. Cloud service provider's data center architecture, including geographically diverse and fault-tolerance architecture should be efficient. With these being

7. Outline the concepts of

- a. Access control in the cloud
- b. Virtual server access control

Access Control in Cloud Computing refers to **the ability to restrict access to information stored on the cloud**. This allows companies to ensure their information is secured and helps minimize risk.

Access control options for users

To give users the ability to create and manage your Compute Engine resources, you can add users as *team members* to your project or to specific resources and grant them permissions using Identity and Access Management (IAM) *roles*.

A team member can be an individual user with a valid Google Account, a Google Group, a service account, or a Google Workspace domain. When you add a team member to a project or to a resource, you specify which roles to grant them. IAM provides three types of roles: predefined roles, basic roles, and custom roles.

The standard practices followed by PaaS customer to reduce software application vulnerability.

The following are best practices for managing the identity perimeter.

Best practice: Secure your keys and credentials to secure your PaaS deployment.

Detail: Losing keys and credentials is a common problem. You can use a centralized solution where keys and secrets can be stored in hardware security modules (HSMs). Azure Key Vault safeguards your keys and secrets by encrypting authentication keys, storage account keys, data encryption keys, .pfx files, and passwords using keys that are protected by HSMs.

Best practice: Don't put credentials and other secrets in source code or GitHub. **Detail:** The only thing worse than losing your keys and credentials is having an unauthorized party gain access to them. Attackers can take advantage of bot technologies to find keys and secrets stored in code repositories such as GitHub. Do not put key and secrets in these public code repositories.

Best practice: Protect your VM management interfaces on hybrid PaaS and IaaS services by using a management interface that enables you to remote manage these VMs directly. **Detail:** Remote management protocols such as SSH, RDP, and PowerShell remoting can be used. In general, we recommend that you do not enable direct remote access to VMs from the internet.

Comparison of IAM standards and protocols

LDAP

The Lightweight Directory Access Protocol (LDAP) is an open-source protocol not associated with any specific vendor, although it does provide the basis for Microsoft's Active Directory. LDAP was established as an industry standard in the 1990s and is among the oldest identity and access management protocols. It runs above the TCP/IP stack and is most often used in modern organizations as a tool to handle authentication for on-premise applications.

As the name suggests, LDAP is associated with directory access. When a user wants to connect to a directory, search its contents or modify the directory itself, LDAP relays the information necessary for authentication and subsequent authorization. The protocol is flexible and can be customized to the needs of systems to make locating and interacting with resources on a network easier and more secure.

SAML

The Security Assertion Markup Language (SAML) protocol is most often used in systems employing the Single Sign-On (SSO) method of access control. In SSO, one set of credentials allows users to access multiple applications. This method is most beneficial when users must move between applications during sessions. Instead of requiring individual logins for each application, SSO makes use of data already authenticated for the session to streamline the switch between applications. The resulting increase in efficiency helps prevent bottlenecks in the authorization process.

SAML is an open standard, making it available to any organization. However, it can't be used to authenticate or authorize device connections and isn't popular for supporting access to internal applications. This effectively limits the protocol to third-party applications, such as the cloud tools used by most modern businesses. As Software-as-a-Service (SaaS) continues to grow in popularity, SAML is an integral part of corporate IAM.

OpenID

Like SAML, OpenID is used for web applications and can be seen in practice when interacting with products from Google and Yahoo! Implementation of this protocol is less complicated than implementation of SAML, making it more accessible for a variety of applications.

Part of the benefit of OpenID for consumer applications is the ability for users to maintain a consistent identity across platforms. It supports the use of a single identifier and password to connect with every service a user is authorized to access. In a web environment, this means the user's avatar and profile remain the same between services. This makes users easier to recognize and preserves the continuity sought by those working to become influencers and thought leaders.

UNIT 5

Common privacy principles of cloud computing

Data in transit protection

User data which is transitioning between networks should be protected against any interference.

Asset protection and resilience

User data, and the assets storing or processing it, should be protected against physical tampering, loss, damage or seizure.

Separation between users

If a user of a service is compromised by malicious software, this should not affect the service or data of another user.

Governance framework

A Security Governance Framework should be followed by the service

provider, in order to internally coordinate its management of the service.

Operational security

In order to prevent and detect attacks, the service must be operated securely. Adequate security shouldn't require complex or expensive processes.

Personnel security

Service provider personnel should be thoroughly screened, followed by in-depth training to reduce the likelihood of accidental or malicious compromise.

Secure development

Services should be designed with security in mind. Nexor is proud to follow a Secure by Design approach.

Supply chain security

The service provider should ensure that their supply chain adheres to all of the same security principles – read more about this in our Supply Chain blog.

Secure user management

Your service provider should ensure that you have the relevant tools to securely manage the use of their services. Management interfaces prevent unauthorised access to your data, making them a vital part of the security barrier.

Identity and authentication

Access to the service interfaces should only be granted to specific individuals

and should all be guarded by adequate authentication measures – two party authentication if possible.

Secure service administration

If a cloud service is compromised through its administration system, important company data could be stolen or manipulated. It is vital that these services are secure.

Audit information for users

A service provider should supply their customers with the audit recorded needed to monitor the service and who is able to access your data. This is vital as it gives you a means to identify inappropriate or malicious activity.

Secure use of service

You have a responsibility to ensure the service is used properly, to ensure your data is kept safe and protected.

Legal and regulatory requirements for data privacy

- **Purpose limitation.** The collection and use of personal data should be limited to purposes: (1) which are stated in law and thus can be known (at least in theory) to the individual at the time of the data collection; or (2) for which the individual has given consent.
- **Proportionality and minimization.** The data collected must be *proportionate to the purpose* of the ID system in order to avoid unnecessary data collection and “function creep,” both of which can create privacy risks. This is often articulated as requiring that only the “minimum necessary” data—including transaction metadata—should be collected to fulfil the intended purpose.
- **Lawfulness.** The collection and use of personal data should be done on a lawful basis, e.g., involving consent, contractual necessity, compliance with legal obligation, protection of vital interests, public interest and/or legitimate interest.
- **Fairness and transparency.** The collection and use of personal data should be done fairly and transparently.

Accuracy. Personal data should be accurate and up-to-date, and inaccuracies should be expediently corrected.

Cloud Computing Benefits

1. **Improved software and hardware performance**– through cloud computing solution one can easily make out what will be the best software and hardware specification for the better performance of the application running on the cloud.
2. **Flexibility and affordability**– Cloud Computing provides its users with a wide variety of deployment models and functions through which they can choose the best options for their applications. Cloud services are much more affordable.
3. **Increased uptime and availability**– it is highly available and has a great uptime which helps in managing more amount of traffic at a particular time.

Better collaboration with real-time sharing– cloud computing has great real-time sharing.

The key components of GRC.

Risk assessment

This approach begins with an assessment of the risks that face the CSP and identification of the specific compliance regimes/requirements that are applicable to the CSP's services. The CSP should address risks associated with key areas such as appropriate user authentication mechanisms for accessing the cloud, encryption of sensitive data and

Key controls

Key controls are then identified and documented to address the identified risks and compliance requirements. These key controls are captured in a unified control set that is designed to meet the requirements of the CSP's customers and other external requirements. The CSP drives compliance activities based on its key controls rather than disparate sets of externally generated compliance requirements.

Monitoring

Monitoring and testing processes are defined and executed on an ongoing basis for key controls. Gaps requiring remediation are identified with remediation progress tracked.

The results of ongoing monitoring activities may also be used to support any required external audits. Refer to [“Auditing the Cloud for Compliance” on page 194](#) for a discussion of external audit approaches.

Reporting

Metrics and key performance indicators (KPIs) are defined and reported on an ongoing basis. Reports of control effectiveness and trending are made available to CSP management and external customers, as appropriate.

Continuous improvement

Management improves its controls over time—acting swiftly to address any

significant gaps identified during the course of monitoring and taking advantage of opportunities to improve processes and controls.

Risk assessment—new IT projects and systems

The CSP performs a risk assessment as new IT projects, systems, and services are developed to identify new risks and requirements, to assess the impact on the CSP's current controls, and to determine whether additional or modified controls and monitoring processes are needed.

The CSP also performs an assessment when considering entry into a new industry or market or taking on a major new client with unique control requirements.

Illustrative control objectives of asset, communication and operations management for cloud computing.

Responsibility for assets

To achieve and maintain appropriate protection of organizational assets

Information classification

To ensure that information receives an appropriate level of protection

Prior to employment

To ensure that employees, contractors, and third-party users understand their responsibilities and are suitable for the roles they are considered for, and to reduce the risk of theft, fraud, or misuse of facilities

During employment

To ensure that all employees, contractors, and third-party users are aware of information security threats and concerns and of their responsibilities and liabilities, and are equipped to support an organizational security policy in the course of their normal work, and to reduce the risk of human error

Termination or change of employment

To ensure that employees, contractors, and third-party users exit an organization or change employment in an orderly manner.

Illustrative control objectives of security policy and access control for cloud computing.

Business requirement for access control

To control access to information

User access management

To ensure authorized user access and to prevent unauthorized access to information systems

User responsibilities

To prevent unauthorized user access, and compromise or theft of information and information processing facilities

Network access control

To prevent unauthorized access to networked services

Operating system access control

To prevent unauthorized access to operating systems

Application and information access control

To prevent unauthorized access to information held in application systems

Mobile computing and teleworking

To ensure Information security when using mobile computing and teleworking facilities.

Key management control objectives

Where encryption is used, effective key management controls are critically important to help ensure the confidentiality and availability of sensitive data. Here are the relevant key management control objectives.

Key management

Key generation practices

Cryptographic keys are generated in accordance with industry standards, including:

- Random or pseudorandom number generation
- Prime number generation

Key generation algorithms

- Hardware and software components
- References to the key generation procedural documentation

Key storage, backup, and recovery practices

Asymmetric private keys and symmetric keys remain secret and their integrity and authenticity are retained, including:

- Key separation mechanisms
- Hardware and software components
- References to key storage, backup, and recovery procedures

- Business continuity management documentation

Key distribution practices

Secrecy of asymmetric private keys, symmetric keys, and keying material, and the integrity and authenticity of all keys and keying material, are maintained during key distribution, including:

- Initial key distribution processes
- Subsequent key replacement processes
- Key synchronization mechanisms

References to the key distribution procedural documentation.

Cloud Security Alliance

The primary objective of CSA are:

- Promote a common level of understanding between the consumers and providers of cloud computing regarding the necessary security requirements and attestation of assurance.
- Promote independent research into best practices for cloud computing security.
- Launch awareness campaigns and educational programs on the appropriate uses of cloud computing and cloud security solutions.
- Create consensus lists of issues and guidance for cloud security assurance.

CSA has published a white paper (available at <http://www.cloudsecurityalliance.org>) that focuses on areas of concern that are either unique to cloud computing or are greatly exacerbated by the model.

The white paper attempts to discuss cloud computing practice, relevant security issues, and guidance, organized under 15 domains:

- Cloud Computing Architectural Framework
- Governance and Enterprise Risk Management
- Legal
- Electronic Discovery
- Compliance and Audit
- Information Lifecycle Management
- Portability and Interoperability.

Internal and external audit of cloud computing

An external audit of the CSP will likely be required for customers to gain comfort in the effectiveness of the CSP's controls. Historically, a variety of audit frameworks have been used to assess the controls of outsourced service providers, including CSPs. Some of the most common audit frameworks are summarized here and described in the section that follows.

Although some CSPs have been completing such external audits for five or more years, an

increasing number of CSPs are now initiating external audits for the first time in response to increasing market pressure.

Internal Audit Perspective

As we discussed earlier, a programmatic approach to compliance is particularly important in a cloud computing environment as the impact of a control failure could be quite severe. The CSP cannot afford to wait until the annual external audit to determine whether controls have operated effectively during the past year, because of the increased potential for control failures impacting multiple customers. Key controls must be identified early on and proactively monitored so that any potential issues can be investigated and addressed in a timely manner. For example, a failure to detect errors in the automated system configuration and activity logging processes on a near-real-time basis could lead to system downtime, breached security, or data loss. Although controls should be designed to prevent the occurrence of such issues, near-real-time detection and rapid correction of any such issues will go a long way toward demonstrating the CSP's commitment to security and continuous improvement.
